DLACZEGO SYGNATURY JUŻ NIE WYSTARCZAJĄ: O WYKRYWANIU DOMEN GENEROWANYCH ALGORYTMICZNIE W BOTNETACH

Piotr Białczak
Małgorzata Dębska

Warszawa, 14 października 2015

SECURE 2015

CERT.PL

AGENDA

Wprowadzenie do botnetów

DGA - co to takiego?

Złośliwe wykorzystanie DGA

Niezłośliwe DGA - fałszywe alarmy w systemach detekcji

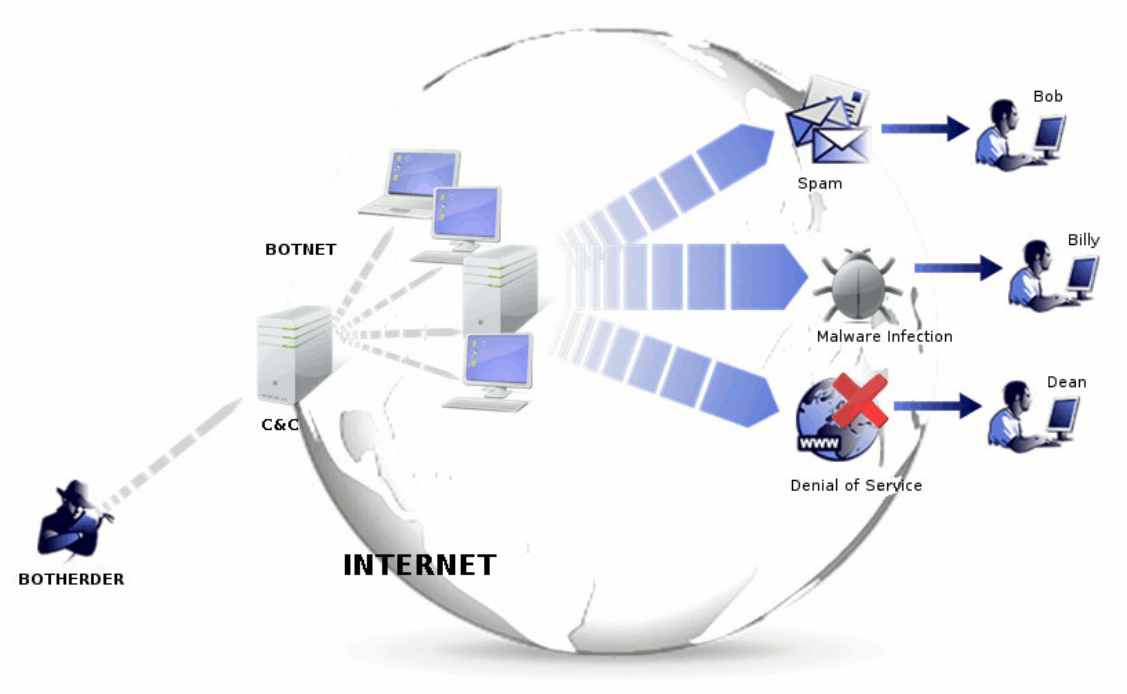
Dlaczego sygnatury już nie wystarczają?

Przegląd metod wykrycia

Podsumowanie

WPROWADZENIE DO BOTNETÓW

TYPOWA ARCHITEKTURA BOTNETU



Struktura:

- Bot
- Bot Master / Herder
- Botnet

PROPAGACJA BOTÓW - WEKTORY ATAKU

- Phishing (np. SPAM)

PROPAGACJA BOTÓW - WEKTORY ATAKU

- Phishing (np. SPAM)
- Zainfekowane nośniki (np. USB Flashdrives)

PROPAGACJA BOTÓW - WEKTORY ATAKU

- Phishing (np. SPAM)
- Zainfekowane nośniki (np. USB Flashdrives)
- Ataki socjotechniczne

PROPAGACJA BOTÓW - WEKTORY ATAKU

- Phishing (np. SPAM)
- Zainfekowane nośniki (np. USB Flashdrives)
- Ataki socjotechniczne
- Zarażone pliki

PROPAGACJA BOTÓW - WEKTORY ATAKU

- Phishing (np. SPAM)
- Zainfekowane nośniki (np. USB Flashdrives)
- Ataki socjotechniczne
- Zarażone pliki
- Zainfekowane aplikacje mobilne

PROPAGACJA BOTÓW - WEKTORY ATAKU

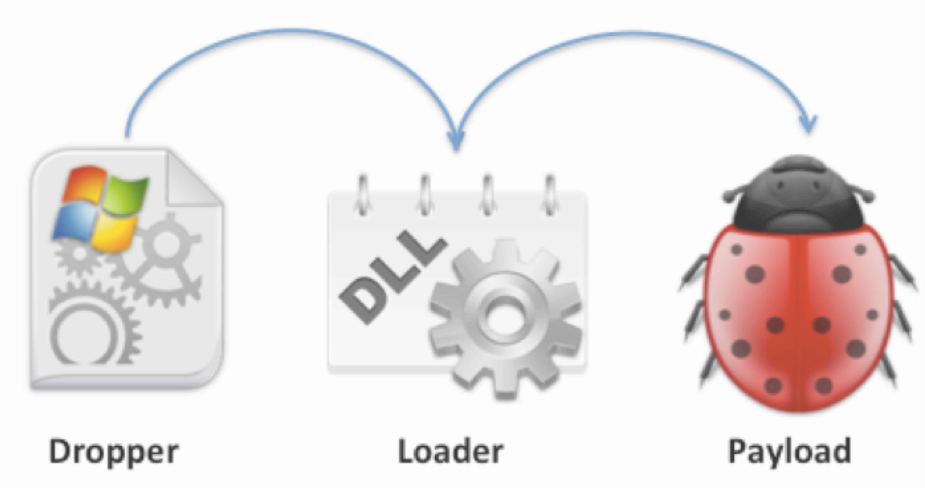
- Phishing (np. SPAM)
- Zainfekowane nośniki (np. USB Flashdrives)
- Ataki socjotechniczne
- Zarażone pliki
- Zainfekowane aplikacje mobilne
- Zatruwanie DNS

PROPAGACJA BOTÓW - WEKTORY ATAKU

- Phishing (np. SPAM)
- Zainfekowane nośniki (np. USB Flashdrives)
- Ataki socjotechniczne
- Zarażone pliki
- Zainfekowane aplikacje mobilne
- Zatruwanie DNS

PROPAGACJA BOTÓW - WEKTORY ATAKU

- Phishing (np. SPAM)
- Zainfekowane nośniki (np. USB Flashdrives)
- Ataki socjotechniczne
- Zarażone pliki
- Zainfekowane aplikacje mobilne
- Zatruwanie DNS



KOMUNIKACJA - ADRESY SERWERÓW C&C

```
push    ebp
mov     ebp, esp
mov     eax, 195E8h
call    __alloca_probe
mov     eax, ___security_cookie
xor     eax, ebp
mov     [ebp+var_4], eax
push    ebx
push    edi
push    offset name     ; "chromeupdatecenter.com"
push    1
push    1
lea     eax, [ebp+buf]
push    offset aGetDDHttp1_1Ho ; "GET /%d/%d HTTP/1.1\nHost: %s\nAccept:
xor     ebx, ebx
push    eax             ;; char aGetDDHttp1_1Ho[]
mov     [ebp+var_193B4], aGetDDHttp1_1Ho db 'GET /%d/%d HTTP/1.1',0Ah ;
call    _sprintf                          db 'Host: %s',0Ah
push    1               ;                 db 'Accept: text/html',0Ah
push    0FFFFh          ;                 db 'Connection: keep-alive',0Ah
call    _calloc                           db 'BroAgent: needle',0Dh,0Ah
add     esp, 1Ch                          db 0Dh,0Ah,0
lea     ecx, [ebp+WSAData]
push    ecx             ; lpWSAData
push    101h            ; wVersionRequested
mov     [ebp+var_193C4], eax
mov     [ebp+argp], 1
mov     [ebp+var_193B0], ebx
mov     [ebp+var_193A9], bl
call    ds:WSAStartup
test    eax, eax
```

- adresy ”zaszyte” w kodzie programu

KOMUNIKACJA - ADRESY SERWERÓW C&C

```
push    ebp
mov     ebp, esp
mov     eax, 195E8h
call    __alloca_probe
mov     eax, ___security_cookie
xor     eax, ebp
mov     [ebp+var_4], eax
push    ebx
push    edi
push    offset name     ; "chromeupdatecenter.com"
push    1
push    1
lea     eax, [ebp+buf]
push    offset aGetDDHttp1_1Ho ; "GET /%d/%d HTTP/1.1\nHost: %s\nAccept:
xor     ebx, ebx
push    eax             ;; char aGetDDHttp1_1Ho[]
mov     [ebp+var_193B4], aGetDDHttp1_1Ho db 'GET /%d/%d HTTP/1.1',0Ah ;
call    _sprintf                          db 'Host: %s',0Ah
push    1               ;                 db 'Accept: text/html',0Ah
push    0FFFFh          ;                 db 'Connection: keep-alive',0Ah
call    _calloc                           db 'BroAgent: needle',0Dh,0Ah
add     esp, 1Ch                          db 0Dh,0Ah,0
lea     ecx, [ebp+WSAData]
push    ecx             ; lpWSAData
push    101h            ; wVersionRequested
mov     [ebp+var_193C4], eax
mov     [ebp+argp], 1
mov     [ebp+var_193B0], ebx
mov     [ebp+var_193A9], bl
call    ds:WSAStartup
test    eax, eax
```

- adresy ”zaszyte” w kodzie programu
- domena musi zostać zarejestrowana z wyprzedzeniem

KOMUNIKACJA - ADRESY SERWERÓW C&C

```
push    ebp
mov     ebp, esp
mov     eax, 195E8h
call    __alloca_probe
mov     eax, ___security_cookie
xor     eax, ebp
mov     [ebp+var_4], eax
push    ebx
push    edi
push    offset name     ; "chromeupdatecenter.com"
push    1
push    1
lea     eax, [ebp+buf]
push    offset aGetDDHttp1_1Ho ; "GET /%d/%d HTTP/1.1\nHost: %s\nAccept:
xor     ebx, ebx
push    eax             ;; char aGetDDHttp1_1Ho[]
mov     [ebp+var_193B4], aGetDDHttp1_1Ho db 'GET /%d/%d HTTP/1.1',0Ah ;
call    _sprintf                          db 'Host: %s',0Ah
push    1               ;                 db 'Accept: text/html',0Ah
push    0FFFFh          ;                 db 'Connection: keep-alive',0Ah
call    _calloc                           db 'BroAgent: needle',0Dh,0Ah
add     esp, 1Ch                          db 0Dh,0Ah,0
lea     ecx, [ebp+WSAData]
push    ecx             ; lpWSAData
push    101h            ; wVersionRequested
mov     [ebp+var_193C4], eax
mov     [ebp+argp], 1
mov     [ebp+var_193B0], ebx
mov     [ebp+var_193A9], bl
call    ds:WSAStartup
test    eax, eax
```

- adresy ”zaszyte” w kodzie programu
- domena musi zostać zarejestrowana z wyprzedzeniem
- duże prawdopodobieństwo blacklistowania domeny

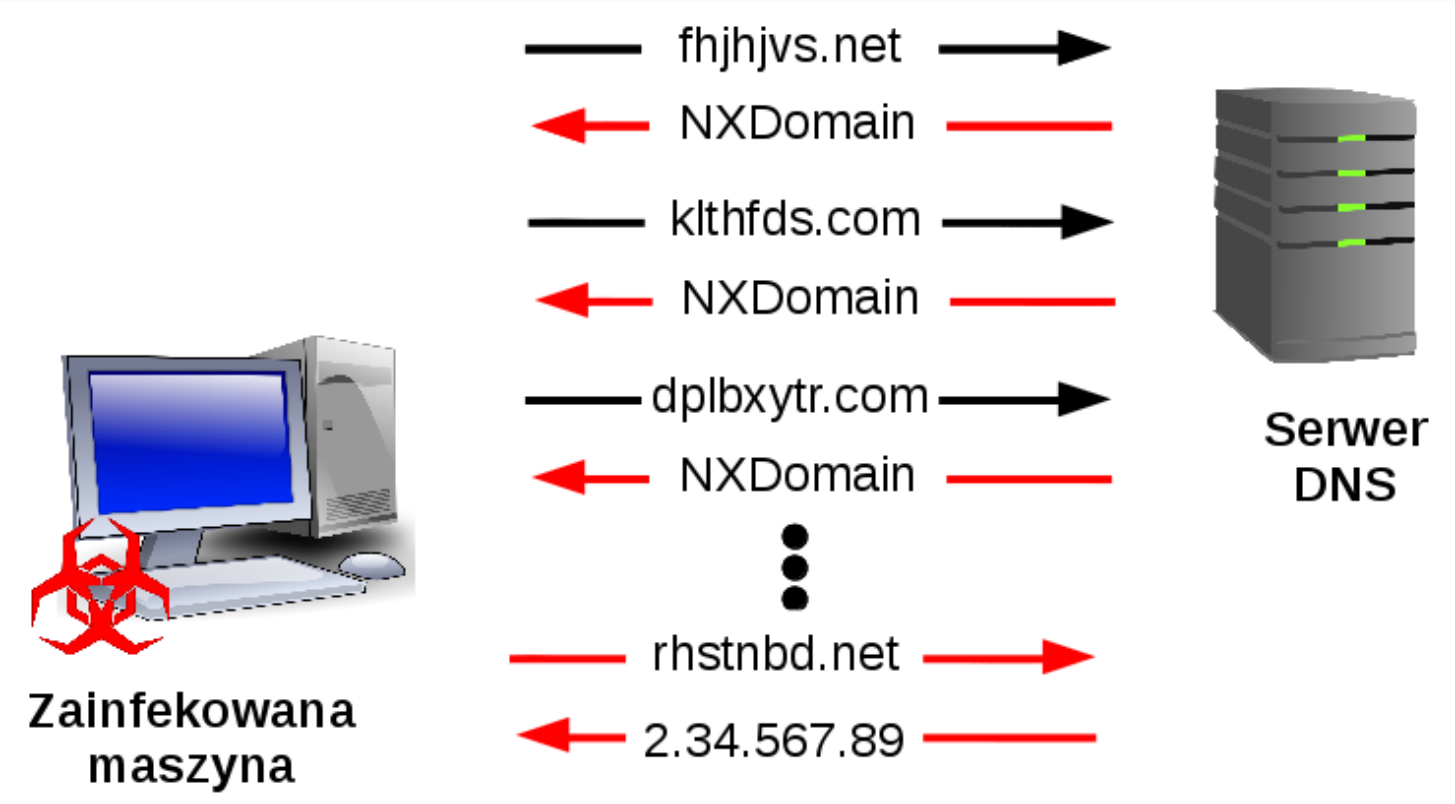
KOMUNIKACJA - ADRESY SERWERÓW C&C

```
push    ebp
mov     ebp, esp
mov     eax, 195E8h
call    __alloca_probe
mov     eax, ___security_cookie
xor     eax, ebp
mov     [ebp+var_4], eax
push    ebx
push    edi
push    offset name     ; "chromeupdatecenter.com"
push    1
push    1
lea     eax, [ebp+buf]
push    offset aGetDDHttp1_1Ho ; "GET /%d/%d HTTP/1.1\nHost: %s\nAccept:
xor     ebx, ebx
push    eax             ;; char aGetDDHttp1_1Ho[]
mov     [ebp+var_193B4], aGetDDHttp1_1Ho db 'GET /%d/%d HTTP/1.1',0Ah ;
call    _sprintf                          db 'Host: %s',0Ah
push    1               ;                 db 'Accept: text/html',0Ah
push    0FFFFh          ;                 db 'Connection: keep-alive',0Ah
call    _calloc                           db 'BroAgent: needle',0Dh,0Ah
add     esp, 1Ch                          db 0Dh,0Ah,0
lea     ecx, [ebp+WSAData]
push    ecx             ; lpWSAData
push    101h            ; wVersionRequested
mov     [ebp+var_193C4], eax
mov     [ebp+argp], 1
mov     [ebp+var_193B0], ebx
mov     [ebp+var_193A9], bl
call    ds:WSAStartup
test    eax, eax
```

- adresy ”zaszyte” w kodzie programu
- domena musi zostać zarejestrowana z wyprzedzeniem
- duże prawdopodobieństwo blacklistowania domeny
- trudności ze zmianą adresu C&C

DGA - CO TO TAKIEGO?

DOMENY GENEROWANE ALGORYTMICZNIE



RÓŻNICE W GENEROWANYCH DOMENACH

- losowość znaków

RÓŻNICE W GENEROWANYCH DOMENACH

- losowość znaków
- zestaw znaków

RÓŻNICE W GENEROWANYCH DOMENACH

- losowość znaków
- zestaw znaków
- rozłożenie częstotliwości używanych znaków

RÓŻNICE W GENEROWANYCH DOMENACH

- losowość znaków
- zestaw znaków
- rozłożenie częstotliwości używanych znaków
- długość generowanych domen

RÓŻNICE W GENEROWANYCH DOMENACH

- losowość znaków
- zestaw znaków
- rozłożenie częstotliwości używanych znaków
- długość generowanych domen
- poziom domeny

RÓŻNICE W GENEROWANYCH DOMENACH

- losowość znaków
- zestaw znaków
- rozłożenie częstotliwości używanych znaków
- długość generowanych domen
- poziom domeny
- używany zestaw domen pierwszego poziomu

PRZYKŁADY

tinba-dga

jmqvlmmbred2e.com
fg4zstnd3ftwh.net
qeh2p2u9pd3i1.com
pttthldqrdt.net

dircrypt

mhrmhuxlcvkxay.com
ctskthnhq.com
safkylboxhb.com

simda

lykef.eu
qekol.eu
puzej.eu
galin.eu

PRZYKŁADY

tinba-dga

jmqvlmmbred2e.com
fg4zstnd3ftwh.net
qeh2p2u9pd3i1.com
pttthldqrdt.net

dircrypt

mhrmhuxlcvkxay.com
ctskthnhq.com
safkylboxhb.com

simda

lykef.eu
qekol.eu
puzej.eu
galin.eu

dyre

a3f6e2d182a40304a8874e994a294ec314.cc
b5191b0ad53da1f1fa66653610e7601856.ws
cc466dc54278d8e0fe14bdd2038b927e6f.to

gameover-zeus

1g22l018lpt4alpeypioqq24k.com
1yz3uuo1yg5zmf1u7goe81sy0xy9.net
1fhvdfa1hr7na1gu9vmv6r710j.biz
5bpzt0njqbkqlbwupc8vi3yt.org

banjori

xjsrrsensinaix.com
hlrfrsensinaix.com
antisemitismgavenuteq.com
bnmtsemitismgavenuteq.com

ZŁOŚLIWE WYKORZYSTANIE DGA

POŁĄCZENIE Z SERWEREM C&C

W każdej sekundzie zainfekowane hosty starają się połączyć z setkami/tysiącami algorytymicznie wygenerowanych domen.

- wysłanie zapytania o rekord A konkretnej domeny

```
Standard query A tmcmefxxssrl.info.localdomain
Standard query response, No such name
Standard query A btchfxgupqxg.com
Standard query response, No such name
Standard query A btchfxgupqxg.com.localdomain
Standard query response, No such name
Standard query A oxwqodvowcgr.net
Standard query response, No such name
Standard query A oxwqodvowcgr.net.localdomain
Standard query response, No such name
Standard query A cxmihhlfwott.biz
Standard query A cxmihhlfwott.biz
Standard query response, No such name
Standard query A cxmihhlfwott.biz.localdomain
Standard query A cxmihhlfwott.biz.localdomain
Standard query response, No such name
Standard query response, No such name
Standard query response, No such name
Standard query A pchrqmbyeacf.ru
Standard query A pchrqmbyeacf.ru
Standard query A pchrqmbyeacf.ru
Standard query response, No such name
Standard query A pchrqmbyeacf.ru.localdomain
Standard query response, No such name
Standard query A pchrqmbyeacf.ru.localdomain
```

POŁĄCZENIE Z SERWEREM C&C

W każdej sekundzie zainfekowane hosty starają się połączyć z setkami/tysiącami algorytymicznie wygenerowanych domen.

```
Standard query A tmcmefxxssrl.info.localdomain
Standard query response, No such name
Standard query A btchfxgupqxg.com
Standard query response, No such name
Standard query A btchfxgupqxg.com.localdomain
Standard query response, No such name
Standard query A oxwqodvowcgr.net
Standard query response, No such name
Standard query A oxwqodvowcgr.net.localdomain
Standard query response, No such name
Standard query A cxmihhlfwott.biz
Standard query A cxmihhlfwott.biz
Standard query response, No such name
Standard query A cxmihhlfwott.biz.localdomain
Standard query A cxmihhlfwott.biz.localdomain
Standard query response, No such name
Standard query response, No such name
Standard query response, No such name
Standard query A pchrqmbyeacf.ru
Standard query A pchrqmbyeacf.ru
Standard query A pchrqmbyeacf.ru
Standard query response, No such name
Standard query A pchrqmbyeacf.ru.localdomain
Standard query response, No such name
Standard query A pchrqmbyeacf.ru.localdomain
```

- wysłanie zapytania o rekord A konkretnej domeny
- większość domen zwraca odpowiedź NX

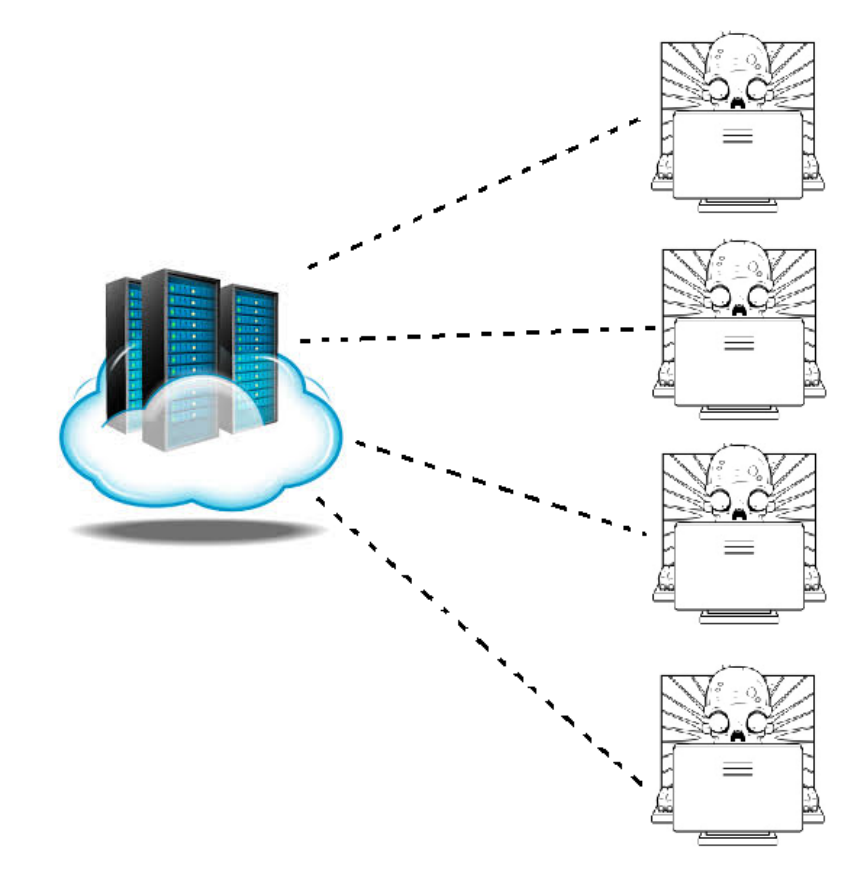
POŁĄCZENIE Z SERWEREM C&C

W każdej sekundzie zainfekowane hosty starają się połączyć z setkami/tysiącami algorytymicznie wygenerowanych domen.

```
Standard query A tmcmefxxssrl.info.localdomain
Standard query response, No such name
Standard query A btchfxgupqxg.com
Standard query response, No such name
Standard query A btchfxgupqxg.com.localdomain
Standard query response, No such name
Standard query A oxwqodvowcgr.net
Standard query response, No such name
Standard query A oxwqodvowcgr.net.localdomain
Standard query response, No such name
Standard query A cxmihhlfwott.biz
Standard query A cxmihhlfwott.biz
Standard query response, No such name
Standard query A cxmihhlfwott.biz.localdomain
Standard query A cxmihhlfwott.biz.localdomain
Standard query response, No such name
Standard query response, No such name
Standard query response, No such name
Standard query A pchrqmbyeacf.ru
Standard query A pchrqmbyeacf.ru
Standard query A pchrqmbyeacf.ru
Standard query response, No such name
Standard query A pchrqmbyeacf.ru.localdomain
Standard query response, No such name
Standard query A pchrqmbyeacf.ru.localdomain
```

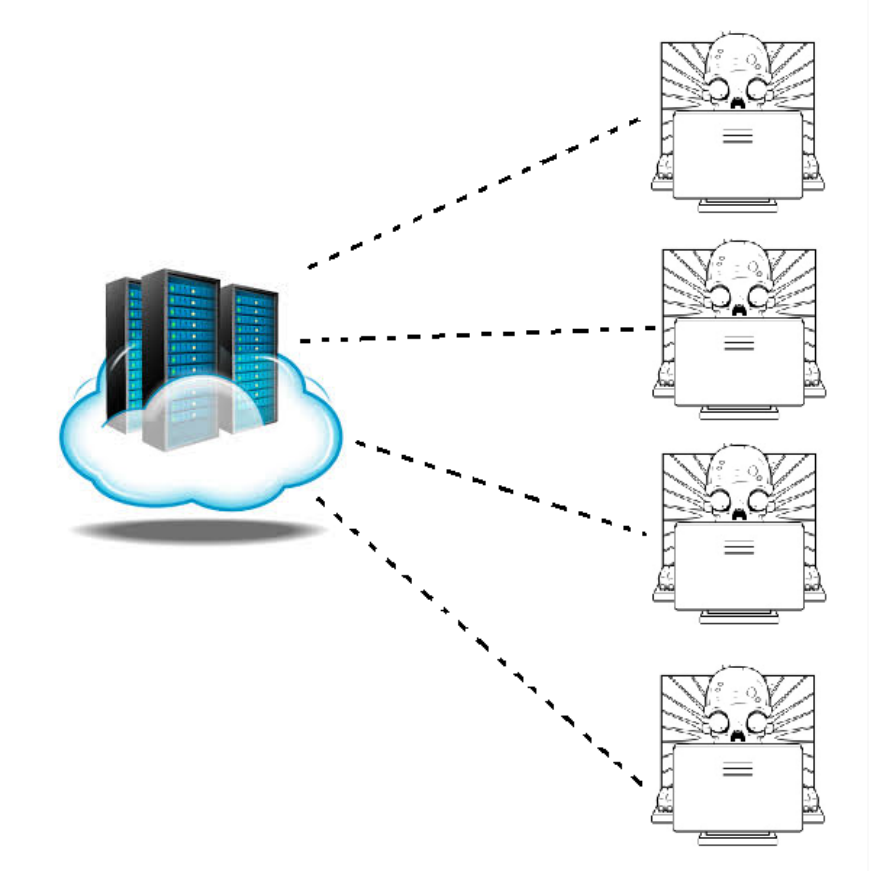
- wysłanie zapytania o rekord A konkretnej domeny
- większość domen zwraca odpowiedź NX
- atakujący musi zarejestrować tylko kilka domen

PRZEBIEG KOMUNIKACJI



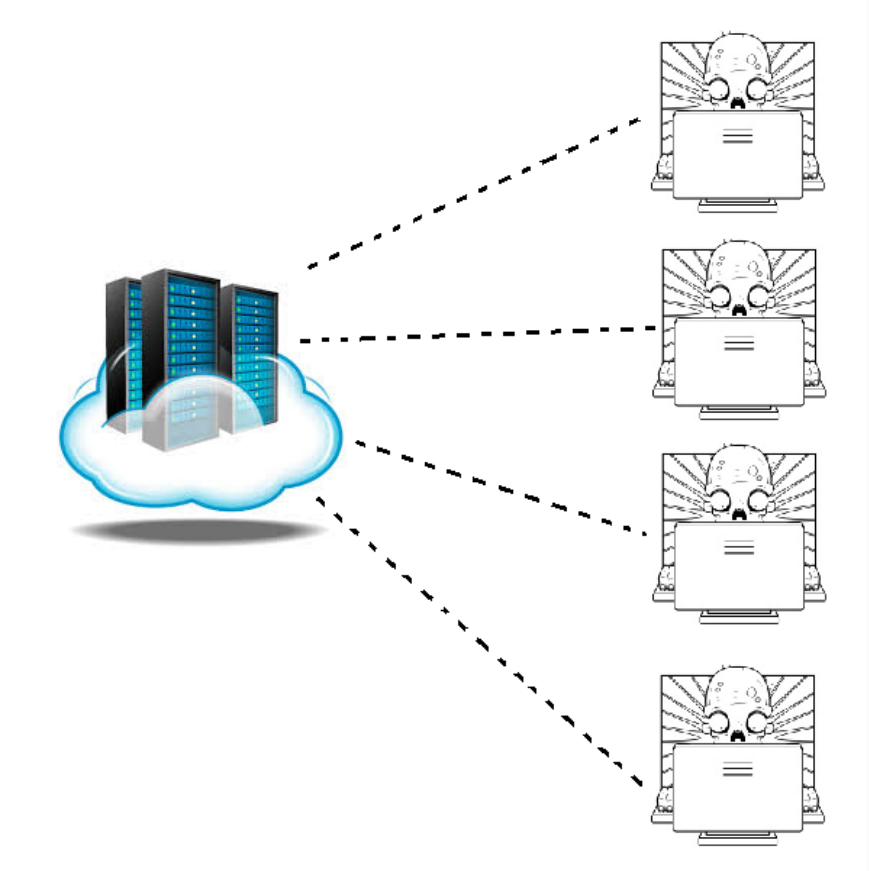
- protokół DNS

PRZEBIEG KOMUNIKACJI



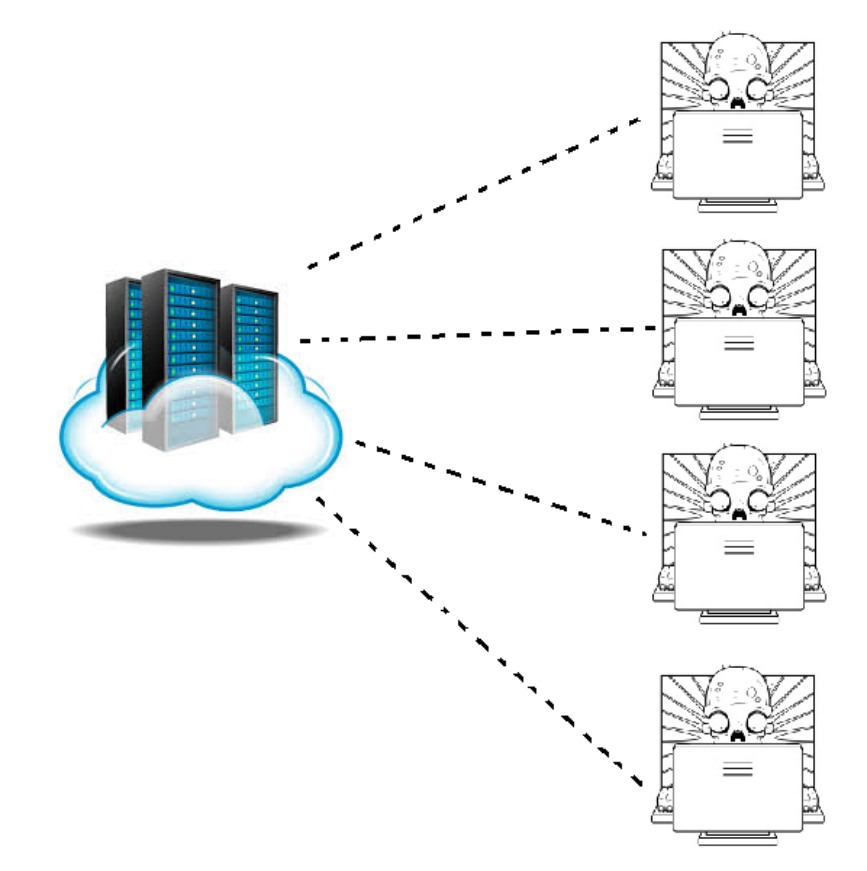
- protokół DNS
- algorytm generowania nazw domenowych

PRZEBIEG KOMUNIKACJI



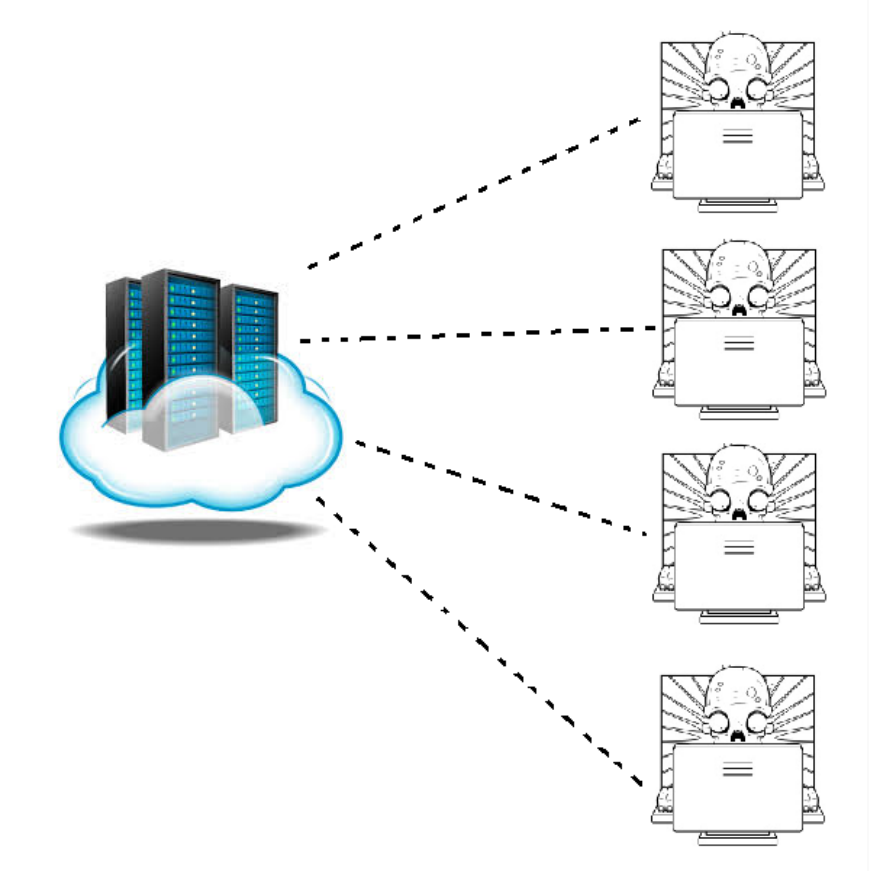
- protokół DNS
- algorytm generowania nazw domenowych
- ziarno generatora współdzielone przez botmastera i ofiarę

PRZEBIEG KOMUNIKACJI



- protokół DNS
- algorytm generowania nazw domenowych
- ziarno generatora współdzielone przez botmastera i ofiarę
- boty wyszukują serwer C&C przy pomocy zapytań DNS

PRZEBIEG KOMUNIKACJI



- protokół DNS
- algorytm generowania nazw domenowych
- ziarno generatora współdzielone przez botmastera i ofiarę
- boty wyszukują serwer C&C przy pomocy zapytań DNS
- ogromny ruch DNS

A gdyby przewidzieć i sinkholować domeny wcześniej?

ZIARNO GENERATORA

Wszystkie domeny generowane algorytmicznie są zależne od konkretnego ziarna

ZIARNO GENERATORA

Wszystkie domeny generowane algorytmicznie są zależne od konkretnego ziarna

- aktualna data (CryptoLocker, Conficker, GameOverZeus)

ZIARNO GENERATORA

Wszystkie domeny generowane algorytmicznie są zależne od konkretnego ziarna

- aktualna data (CryptoLocker, Conficker, GameOverZeus)
- aktualne trendy Twitterowe (Torpig)

ZIARNO GENERATORA

Wszystkie domeny generowane algorytmicznie są zależne od konkretnego ziarna

- aktualna data (CryptoLocker, Conficker, GameOverZeus)
- aktualne trendy Twitterowe (Torpig)
- ziarno zaszyte w złośliwym pliku (Tinba)

ZIARNO GENERATORA

Wszystkie domeny generowane algorytmicznie są zależne od konkretnego ziarna

- aktualna data (CryptoLocker, Conficker, GameOverZeus)
- aktualne trendy Twitterowe (Torpig)
- ziarno zaszyte w złośliwym pliku (Tinba)

ZIARNO GENERATORA

Wszystkie domeny generowane algorytmicznie są zależne od konkretnego ziarna

- aktualna data (CryptoLocker, Conficker, GameOverZeus)
- aktualne trendy Twitterowe (Torpig)
- ziarno zaszyte w złośliwym pliku (Tinba)

```
knpqxlxcwtlvgrdyhd.com
nvlyffua.com
hgyudheedieibxy.com
anrylixwcbnjopdd.com
vrndmdrdrjoff.com
jhghrlufoh.com
tqjhvylf.com
hufqifjq.com
itktxexjghvvxa.com
ppyblaohb.com
```

Figure 1: Ramnit

ZIARNO GENERATORA

Wszystkie domeny generowane algorytmicznie są zależne od konkretnego ziarna

- aktualna data (CryptoLocker, Conficker, GameOverZeus)
- aktualne trendy Twitterowe (Torpig)
- ziarno zaszyte w złośliwym pliku (Tinba)

```
knpqxlxcwtlvgrdyhd.com
nvlyffua.com
hgyudheedieibxy.com
anrylixwcbnjopdd.com
vrndmdrdrjoff.com
jhghrlufoh.com
tqjhvylf.com
hufqifjq.com
itktxexjghvvxa.com
ppyblaohb.com
```

Figure 1: Ramnit

NAJWAŻNIEJSZE: wszystkie boty używają tego samego ziarna w tym samym czasie!

JAKA JEST SKALA PROBLEMU? KTÓRY MALWARE UŻYWA DGA?

- Dyre
- GameoverZeus
- Banjori
- Matsu
- Pushdo
- Emotet
- Pykpsa
- Ramnit
- Conficker
- Bobax
- Murofet
- Necurs
- Shiotob
- Pykspa
- Cryptolocker
- Rovnix
- Emotet
- Gozi
- BankPatch
- Qakbot
- DirCrypt
- Gozi
- Flashback
- Necrus
- Ramdo

i dużo, dużo więcej ...

NIBY INNE A WCIĄŻ DGA

Verbs

```
seg000:7FF964F6 verbs   db 'is',0Dh,0Ah          ; DATA XREF:
seg000:7FF964F6                                  ; Start+CC↑o
seg000:7FF964F6         db 'are',0Dh,0Ah
seg000:7FF964F6         db 'has',0Dh,0Ah
seg000:7FF964F6         db 'get',0Dh,0Ah
seg000:7FF964F6         db 'see',0Dh,0Ah
seg000:7FF964F6         db 'need',0Dh,0Ah
seg000:7FF964F6         db 'know',0Dh,0Ah
seg000:7FF964F6         db 'would',0Dh,0Ah
seg000:7FF964F6         db 'find',0Dh,0Ah
seg000:7FF964F6         db 'take',0Dh,0Ah
seg000:7FF964F6         db 'want',0Dh,0Ah
seg000:7FF964F6         db 'does',0Dh,0Ah
seg000:7FF964F6         db 'learn',0Dh,0Ah
seg000:7FF964F6         db 'become',0Dh,0Ah
seg000:7FF964F6         db 'come',0Dh,0Ah
seg000:7FF964F6         db 'include',0Dh,0Ah
seg000:7FF964F6         db 'thank',0Dh,0Ah
seg000:7FF964F6         db 'provide',0Dh,0Ah
seg000:7FF964F6         db 'create',0Dh,0Ah
seg000:7FF964F6         db 'add',0Dh,0Ah
seg000:7FF964F6         db 'understand',0Dh,0Ah
seg000:7FF964F6         db 'consider',0Dh,0Ah
seg000:7FF964F6         db 'choose',0Dh,0Ah
seg000:7FF964F6         db 'develop',0Dh,0Ah
seg000:7FF964F6         db 'remember',0Dh,0Ah
seg000:7FF964F6         db 'determine',0Dh,0Ah
seg000:7FF964F6         db 'grow',0Dh,0Ah
seg000:7FF964F6         db 'allow',0Dh,0Ah
seg000:7FF964F6         db 'supply',0Dh,0Ah
seg000:7FF964F6         db 'bring',0Dh,0Ah
seg000:7FF964F6         db 'improve',0Dh,0Ah
seg000:7FF964F6         db 'maintain',0Dh,0Ah
```

- nazwa domenowa zawiera losowe znaki alfanumeryczne oraz wyrazy ze słownika

NIBY INNE A WCIĄŻ DGA

Verbs

```
seg000:7FF964F6 verbs   db 'is',0Dh,0Ah          ; DATA XREF:
seg000:7FF964F6                                  ; Start+CC↑o
seg000:7FF964F6         db 'are',0Dh,0Ah
seg000:7FF964F6         db 'has',0Dh,0Ah
seg000:7FF964F6         db 'get',0Dh,0Ah
seg000:7FF964F6         db 'see',0Dh,0Ah
seg000:7FF964F6         db 'need',0Dh,0Ah
seg000:7FF964F6         db 'know',0Dh,0Ah
seg000:7FF964F6         db 'would',0Dh,0Ah
seg000:7FF964F6         db 'find',0Dh,0Ah
seg000:7FF964F6         db 'take',0Dh,0Ah
seg000:7FF964F6         db 'want',0Dh,0Ah
seg000:7FF964F6         db 'does',0Dh,0Ah
seg000:7FF964F6         db 'learn',0Dh,0Ah
seg000:7FF964F6         db 'become',0Dh,0Ah
seg000:7FF964F6         db 'come',0Dh,0Ah
seg000:7FF964F6         db 'include',0Dh,0Ah
seg000:7FF964F6         db 'thank',0Dh,0Ah
seg000:7FF964F6         db 'provide',0Dh,0Ah
seg000:7FF964F6         db 'create',0Dh,0Ah
seg000:7FF964F6         db 'add',0Dh,0Ah
seg000:7FF964F6         db 'understand',0Dh,0Ah
seg000:7FF964F6         db 'consider',0Dh,0Ah
seg000:7FF964F6         db 'choose',0Dh,0Ah
seg000:7FF964F6         db 'develop',0Dh,0Ah
seg000:7FF964F6         db 'remember',0Dh,0Ah
seg000:7FF964F6         db 'determine',0Dh,0Ah
seg000:7FF964F6         db 'grow',0Dh,0Ah
seg000:7FF964F6         db 'allow',0Dh,0Ah
seg000:7FF964F6         db 'supply',0Dh,0Ah
seg000:7FF964F6         db 'bring',0Dh,0Ah
seg000:7FF964F6         db 'improve',0Dh,0Ah
seg000:7FF964F6         db 'maintain',0Dh,0Ah
```

- nazwa domenowa zawiera losowe znaki alfanumeryczne oraz wyrazy ze słownika
- nazwy są tworzone z angielskich sylab

NIEZŁOŚLIWE DGA - FAŁSZYWE ALARMY W SYSTEMACH DETEKCJI

ZAPYTANIA W NARZĘDZIACH ANTYWIRUSOWYCH

Example[1]

0.0.0.0.1.0.0.4e.135jg5e1pd7s4735ftrqweufm5.avqs.mcafee.com
0.0.0.0.1.0.0.4e.13cfus2drmdq3j8cafidezr8l6.avqs.mcafee.com
0.0.0.0.1.0.0.4e.13kqas3qjj46ttkdhastkrdsv6.avqs.mcafee.com
0.0.0.0.1.0.0.4e.13pq3hfpunqn1d51pmvbdkk5s6.avqs.mcafee.com
0.0.0.0.1.0.0.4e.13qh71bf782qb54uzz9uhdz4mq.avqs.mcafee.com

[1] DNS Noise: Measuring the Pervasiveness of Disposable Domains in Modern DNS Traffic, Yizheng Chen et al.

Example[1]

0.0.0.0.1.0.0.4e.135jg5e1pd7s4735ftrqweufm5.avqs.mcafee.com
0.0.0.0.1.0.0.4e.13cfus2drmdq3j8cafidezr8l6.avqs.mcafee.com
0.0.0.0.1.0.0.4e.13kqas3qjj46ttkdhastkrdsv6.avqs.mcafee.com
0.0.0.0.1.0.0.4e.13pq3hfpunqn1d51pmvbdkk5s6.avqs.mcafee.com
0.0.0.0.1.0.0.4e.13qh71bf782qb54uzz9uhdz4mq.avqs.mcafee.com

Domeny wyższych rzędów zawierają podstawowe informacje na temat pliku, jego skrótu, wersji systemu McAffe oraz informacje na temat środowiska wykonywania

[1] DNS Noise: Measuring the Pervasiveness of Disposable Domains in Modern DNS Traffic, Yizheng Chen et al.

INTERNATIONALIZED DOMAIN NAME

Internationalized Domain Name (IDN)	Corresponding punycode
xn--pck3c7di8db7044cmuho9yzlar63kub1ad89aj9u	千葉市看護師求人ハローワーク
xn--gmq274an8aye736be3fesb37bke3a3cn	浍武溉村涯山市師求洧洼人
xn--pck3c7di8db3144cqixa1uczlr63kub1a3q9cy08a	ハローワーク静岡市看護師求人

- IDN-y zawsze zaczynają się od prefiksu ’xn–’

INTERNATIONALIZED DOMAIN NAME

Internationalized Domain Name (IDN)	Corresponding punycode
xn--pck3c7di8db7044cmuho9yzlar63kub1ad89aj9u	千葉市看護師求人ハローワーク
xn--gmq274an8aye736be3fesb37bke3a3cn	浍武溉村涯山市師求洧洼人
xn--pck3c7di8db3144cqixa1uczlr63kub1a3q9cy08a	ハローワーク静岡市看護師求人

- IDN-y zawsze zaczynają się od prefiksu 'xn–'
- Aktualnie IDNy są także wykorzystywane w celach złośliwych

INTERNATIONALIZED DOMAIN NAME

Internationalized Domain Name (IDN)	Corresponding punycode
xn--pck3c7di8db7044cmuho9yzlar63kub1ad89aj9u	千葉市看護師求人ハローワーク
xn--gmq274an8aye736be3fesb37bke3a3cn	浍武溉村涯山市師求洧洼人
xn--pck3c7di8db3144cqixa1uczlr63kub1a3q9cy08a	ハローワーク静岡市看護師求人

- IDN-y zawsze zaczynają się od prefiksu 'xn–'
- Aktualnie IDNy są także wykorzystywane w celach złośliwych

INTERNATIONALIZED DOMAIN NAME

Internationalized Domain Name (IDN)	Corresponding punycode
xn--pck3c7di8db7044cmuho9yzlar63kub1ad89aj9u	千葉市看護師求人ハローワーク
xn--gmq274an8aye736be3fesb37bke3a3cn	浍武溉村涯山市師求洧洼人
xn--pck3c7di8db3144cqixa1uczlr63kub1a3q9cy08a	ハローワーク静岡市看護師求人

- IDN-y zawsze zaczynają się od prefiksu 'xn–'
- Aktualnie IDNy są także wykorzystywane w celach złośliwych

```
⊟ Queries
  ⊟ xn--81by1b3b.xn--h2brj9c: type A, class IN
      Name: xn--81by1b3b.xn--h2brj9c
      [Name Length: 24]
      [Label Count: 2]
      Type: A (Host Address) (1)
      Class: IN (0x0001)
```

DLACZEGO SYGNATURY JUŻ NIE WYSTARCZAJĄ?

- Blokowanie:

- Blokowanie:
  - Nazw domenowych

dvcdjghtwrs.com

alert udp $HOME_NET any -> any 53 (msg:"DNS dvcdjghtwrs.com"; content: "|0b|dvcdjghtwrs|03|com|00|"; nocase; fast_pattern:only; threshold: type limit, track by_src, count 1, seconds 300; classtype:bad-unknown; sid:xx; rev:2;)

- Blokowanie:
  - Nazw domenowych
  - Adresów IP

dvcdjghtwrs.com

```
alert udp $HOME_NET any -> any 53 (msg:"DNS dvcdjghtwrs.com"; content: "|0b|dvcdjghtwrs|03|com|00|"; nocase; fast_pattern:only; threshold: type limit, track by_src, count 1, seconds 300; classtype:bad-unknown; sid:xx; rev:2;)
```

- Blokowanie:
  - Nazw domenowych
  - Adresów IP
- Obserwacja anomalii

dvcdjghtwrs.com

alert udp $HOME_NET any -> any 53 (msg:"DNS dvcdjghtwrs.com"; content: "|0b|dvcdjghtwrs|03|com|00|"; nocase; fast_pattern:only; threshold: type limit, track by_src, count 1, seconds 300; classtype:bad-unknown; sid:xx; rev:2;)

NXDOMAIN

alert udp any 53 -> $HOME_NET any (msg:"ET DNS Excessive NXDOMAIN responses[redacted]"; byte_test:1,&,128,2; byte_test:1,&,1,3; byte_test:1,&,2,3; threshold: type both, track by_src, count 50, seconds 10; classtype:bad-unknown; sid:2008470; rev:6;)

- Blokowanie:
  - Nazw domenowych
  - Adresów IP
- Obserwacja anomalii
- Jak zdobyć blacklisty?

dvcdjghtwrs.com

alert udp $HOME_NET any -> any 53 (msg:"DNS dvcdjghtwrs.com"; content: "|0b|dvcdjghtwrs|03|com|00|"; nocase; fast_pattern:only; threshold: type limit, track by_src, count 1, seconds 300; classtype:bad-unknown; sid:xx; rev:2;)

NXDOMAIN

alert udp any 53 -> $HOME_NET any (msg:"ET DNS Excessive NXDOMAIN responses[redacted]"; byte_test:1,&,128,2; byte_test:1,&,1,3; byte_test:1,&,2,3; threshold: type both, track by_src, count 50, seconds 10; classtype:bad-unknown; sid:2008470; rev:6;)

- Blokowanie:
  - Nazw domenowych
  - Adresów IP
- Obserwacja anomalii
- Jak zdobyć blacklisty?
- Jak nimi zarządzać?

dvcdjghtwrs.com

alert udp $HOME_NET any -> any 53 (msg:"DNS dvcdjghtwrs.com"; content: "|0b|dvcdjghtwrs|03|com|00|"; nocase; fast_pattern:only; threshold: type limit, track by_src, count 1, seconds 300; classtype:bad-unknown; sid:xx; rev:2;)

NXDOMAIN

alert udp any 53 -> $HOME_NET any (msg:"ET DNS Excessive NXDOMAIN responses[redacted]"; byte_test:1,&,128,2; byte_test:1,&,1,3; byte_test:1,&,2,3; threshold: type both, track by_src, count 50, seconds 10; classtype:bad-unknown; sid:2008470; rev:6;)

- Blokowanie:
  - Nazw domenowych
  - Adresów IP
- Obserwacja anomalii
- Jak zdobyć blacklisty?
- Jak nimi zarządzać?
- Co robić z dużą liczbą alarmów?

dvcdjghtwrs.com

alert udp $HOME_NET any -> any 53 (msg:"DNS dvcdjghtwrs.com"; content: "|0b|dvcdjghtwrs|03|com|00|"; nocase; fast_pattern:only; threshold: type limit, track by_src, count 1, seconds 300; classtype:bad-unknown; sid:xx; rev:2;)

NXDOMAIN

alert udp any 53 -> $HOME_NET any (msg:"ET DNS Excessive NXDOMAIN responses[redacted]"; byte_test:1,&,128,2; byte_test:1,&,1,3; byte_test:1,&,2,3; threshold: type both, track by_src, count 50, seconds 10; classtype:bad-unknown; sid:2008470; rev:6;)

WADY SYGNATUR

- Problem ze źródłem domen/adresów IP

WADY SYGNATUR

- Problem ze źródłem domen/adresów IP
- Trudność w zarządzaniu takimi listami

WADY SYGNATUR

- Problem ze źródłem domen/adresów IP
- Trudność w zarządzaniu takimi listami
- Statyczność - brak heurystyki

WADY SYGNATUR

- Problem ze źródłem domen/adresów IP
- Trudność w zarządzaniu takimi listami
- Statyczność - brak heurystyki
- Konieczność zastosowania kosztownej w zasoby analizy wstecznej - dla zdobycia kodu generatorów

WADY SYGNATUR

- Problem ze źródłem domen/adresów IP
- Trudność w zarządzaniu takimi listami
- Statyczność - brak heurystyki
- Konieczność zastosowania kosztownej w zasoby analizy wstecznej - dla zdobycia kodu generatorów
- Brak odkrywania zależności między cechami/zachowaniem

WADY SYGNATUR

- Problem ze źródłem domen/adresów IP
- Trudność w zarządzaniu takimi listami
- Statyczność - brak heurystyki
- Konieczność zastosowania kosztownej w zasoby analizy wstecznej - dla zdobycia kodu generatorów
- Brak odkrywania zależności między cechami/zachowaniem
- Konieczność tworzenia całych zestawów reguł pod konkretny botnet

WADY SYGNATUR

- Problem ze źródłem domen/adresów IP
- Trudność w zarządzaniu takimi listami
- Statyczność - brak heurystyki
- Konieczność zastosowania kosztownej w zasoby analizy wstecznej - dla zdobycia kodu generatorów
- Brak odkrywania zależności między cechami/zachowaniem
- Konieczność tworzenia całych zestawów reguł pod konkretny botnet
- Problemy z poziomem wykrycia i fałszywych alarmów

ALTERNATYWA

Co w zamian?

Co w zamian?

Systemy dedykowane

Główne zalety:

- Biorą pod uwagę wiele zależności

Główne zalety:

- Biorą pod uwagę wiele zależności
- Dają możliwość budowania modeli pewnych cech/zachowań

Główne zalety:

- Biorą pod uwagę wiele zależności
- Dają możliwość budowania modeli pewnych cech/zachowań
- Zapewniają heurystykę

Główne zalety:

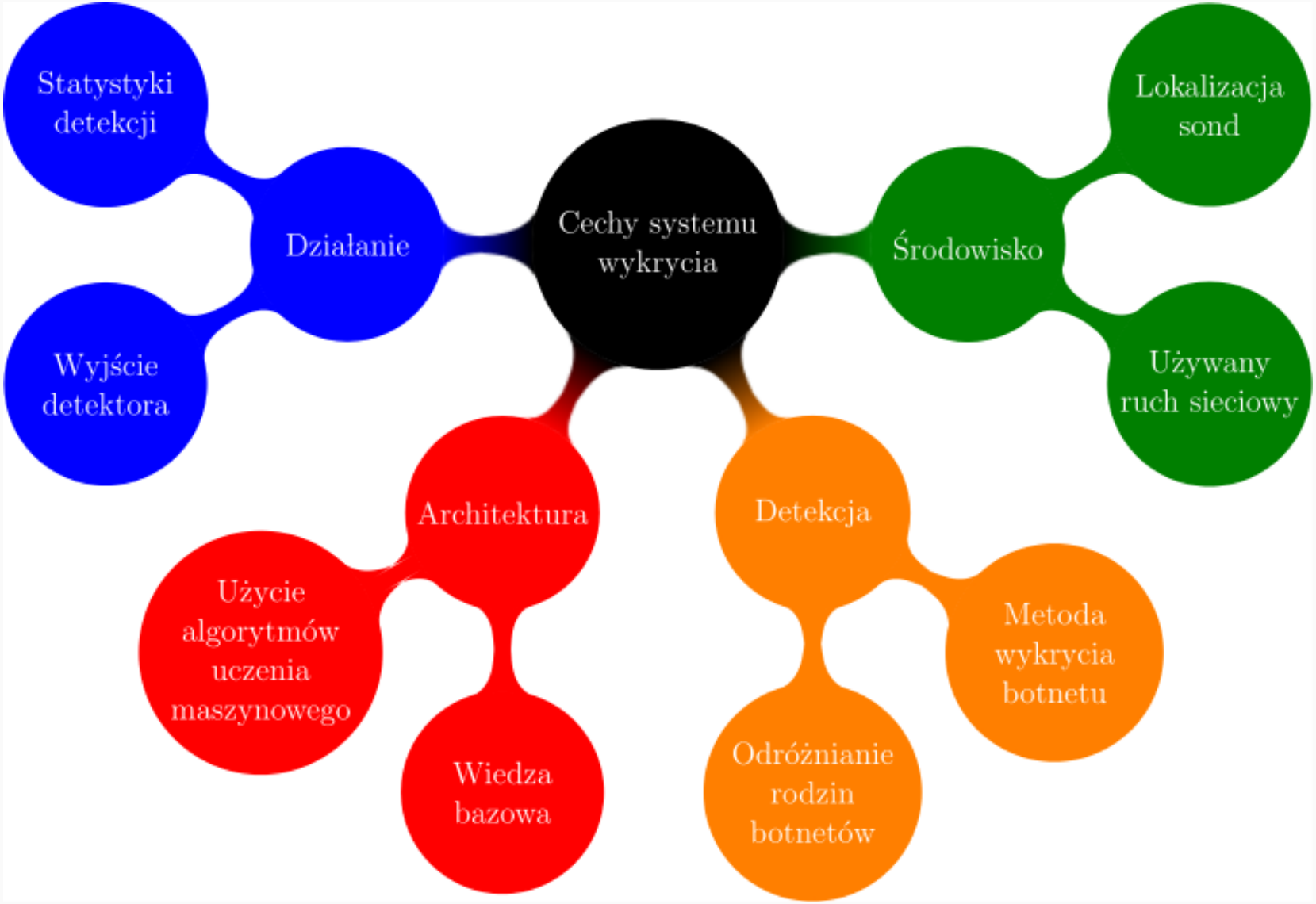
- Biorą pod uwagę wiele zależności
- Dają możliwość budowania modeli pewnych cech/zachowań
- Zapewniają heurystykę
- Lepsze poziomy wykrycia i mniej fałszywych alarmów

Główne zalety:

- Biorą pod uwagę wiele zależności
- Dają możliwość budowania modeli pewnych cech/zachowań
- Zapewniają heurystykę
- Lepsze poziomy wykrycia i mniej fałszywych alarmów
- Są dedykowane...

PRZEGLĄD METOD WYKRYCIA

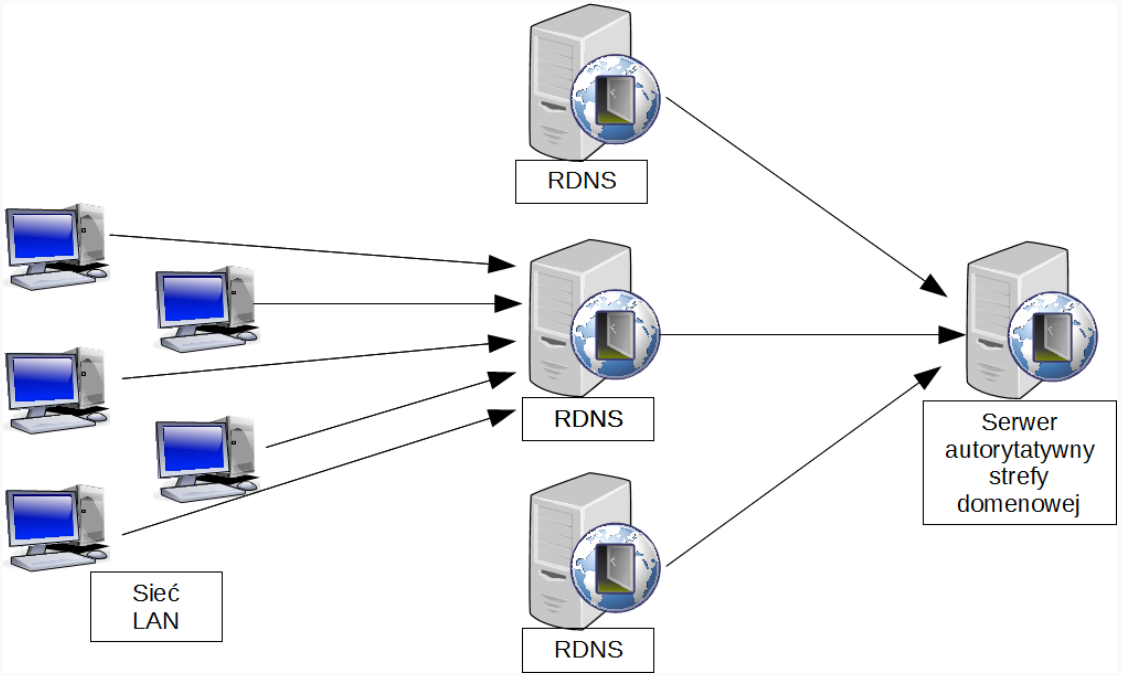
CECHY METOD WYKRYCIA

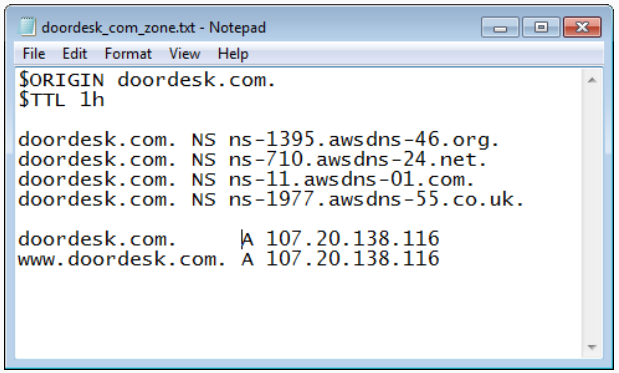


ŚRODOWISKO

Środowisko:

- Lokalizacja sond (LAN, powyżej RDNS, serwer autorytatywny)

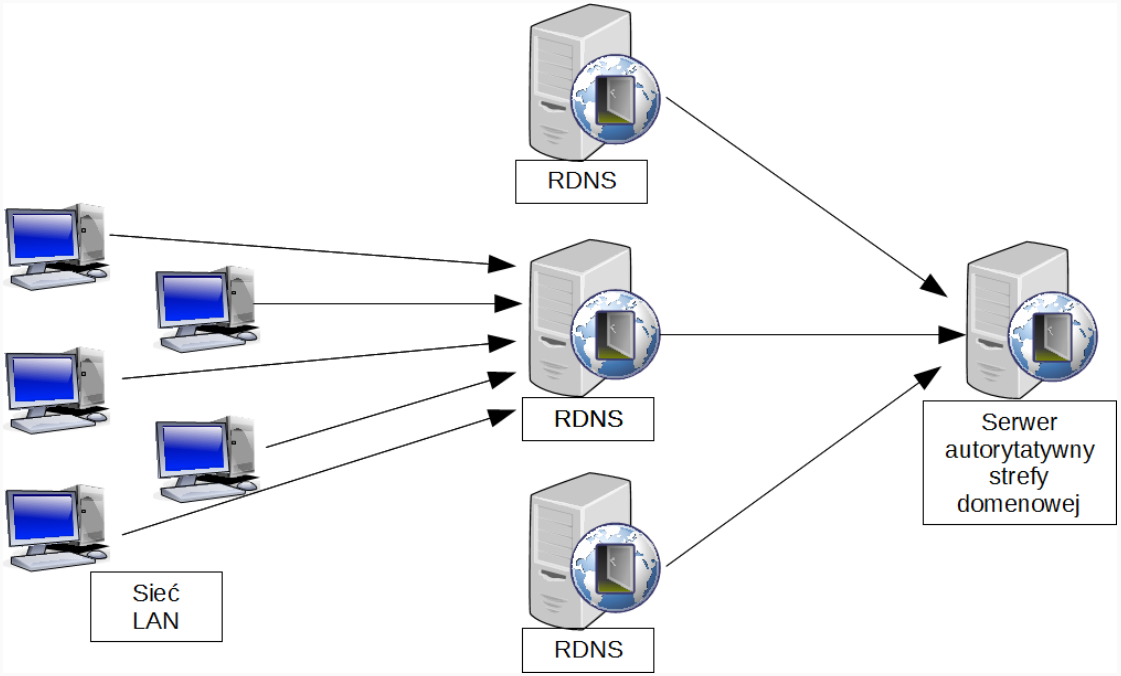


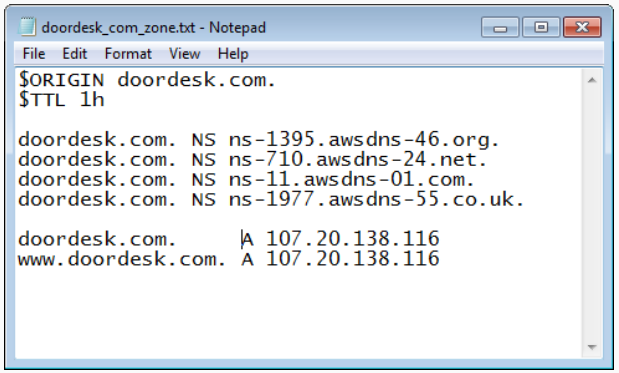


ŚRODOWISKO

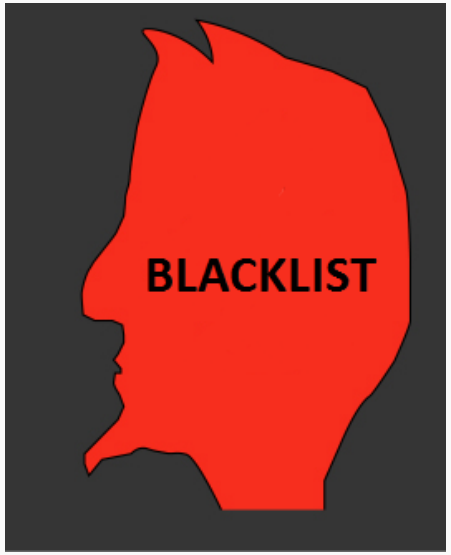
Środowisko:

- Lokalizacja sond (LAN, powyżej RDNS, serwer autorytatywny)
- Używany ruch sieciowy (NXDomain, XDomain, NX+DX, nazwy domenowe)

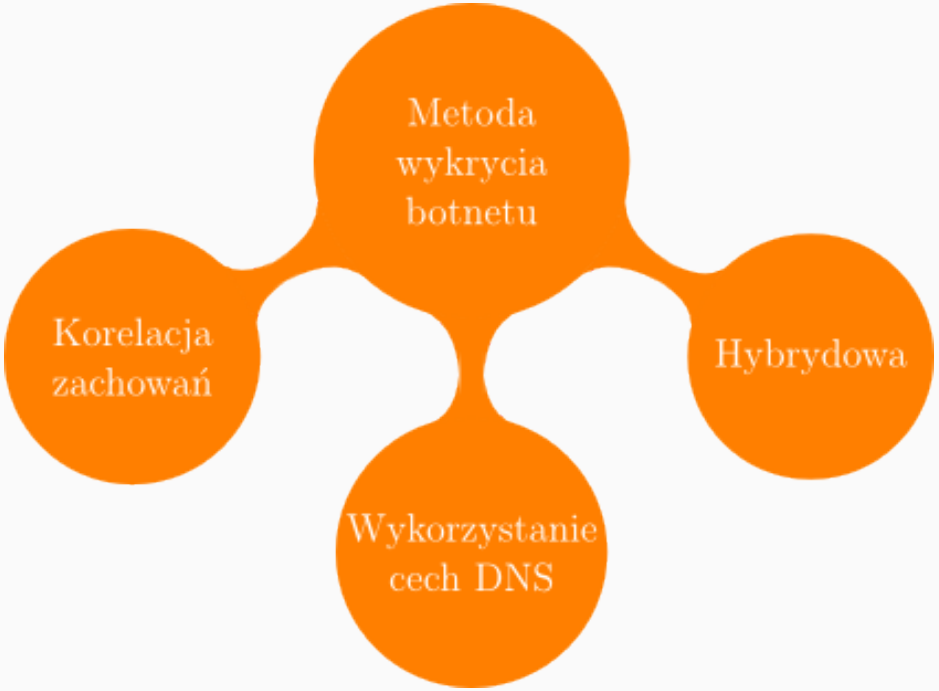




Wiedza bazowa



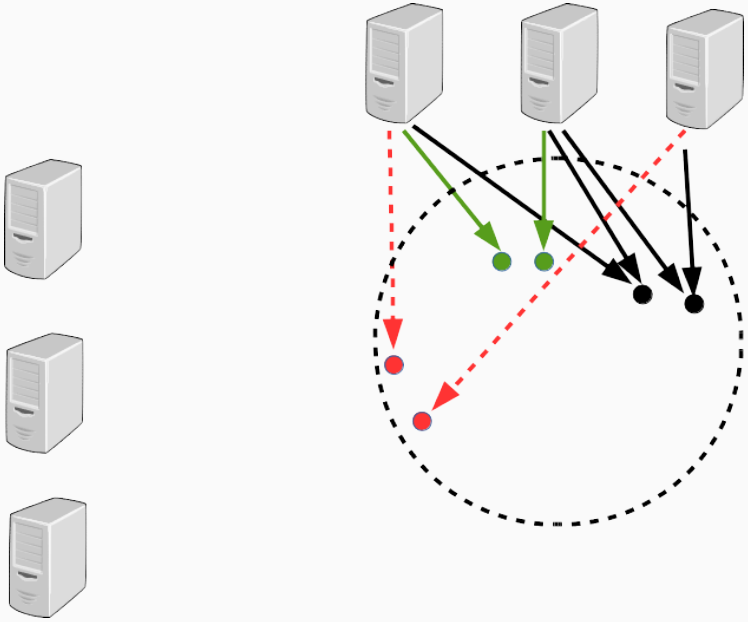
KLASYFIKACJA



Podział systemów ze względu na wykorzystaną metodę wykrycia.

KORELACJA ZACHOWAŃ

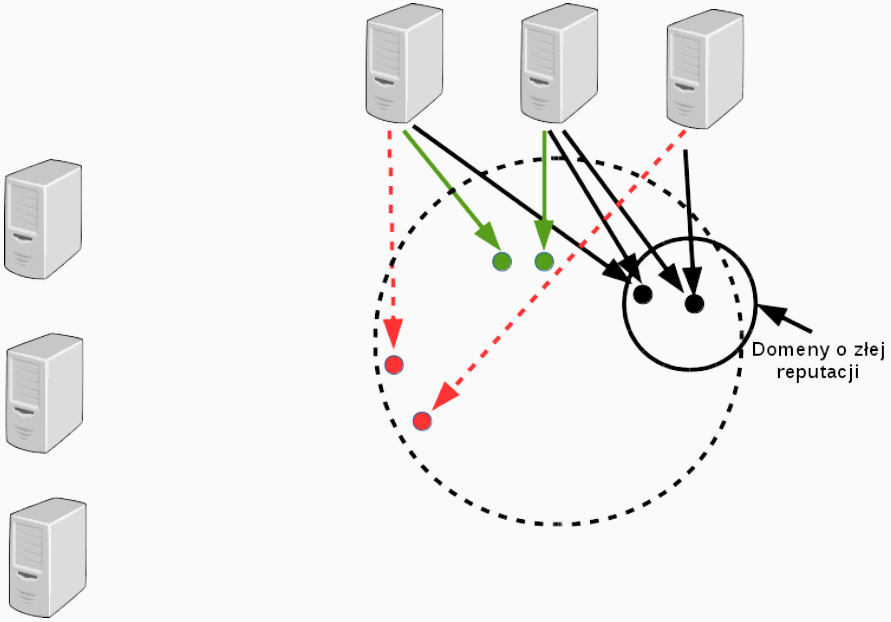
Extending Black Domain Name List by Using Co-occurrence Relation between DNS Queries, K. Sato i in.



1. Zebranie zapytań domenowych

KORELACJA ZACHOWAŃ

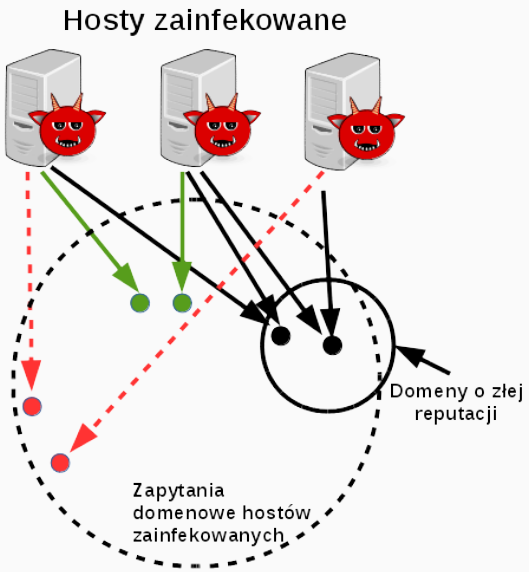
Extending Black Domain Name List by Using Co-occurrence Relation between DNS Queries, K. Sato i in.



1. Zebranie zapytań domenowych
2. Sprawdzenie, które stacje pytały o złośliwe domeny

KORELACJA ZACHOWAŃ

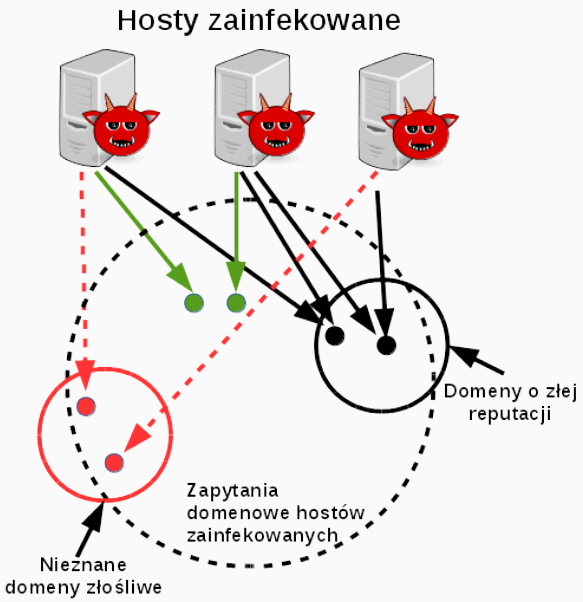
Extending Black Domain Name List by Using Co-occurrence Relation between DNS Queries, K. Sato i in.



1. Zebranie zapytań domenowych
2. Sprawdzenie, które stacje pytały o złośliwe domeny
3. Oznaczenie ich jako zainfekowane

KORELACJA ZACHOWAŃ

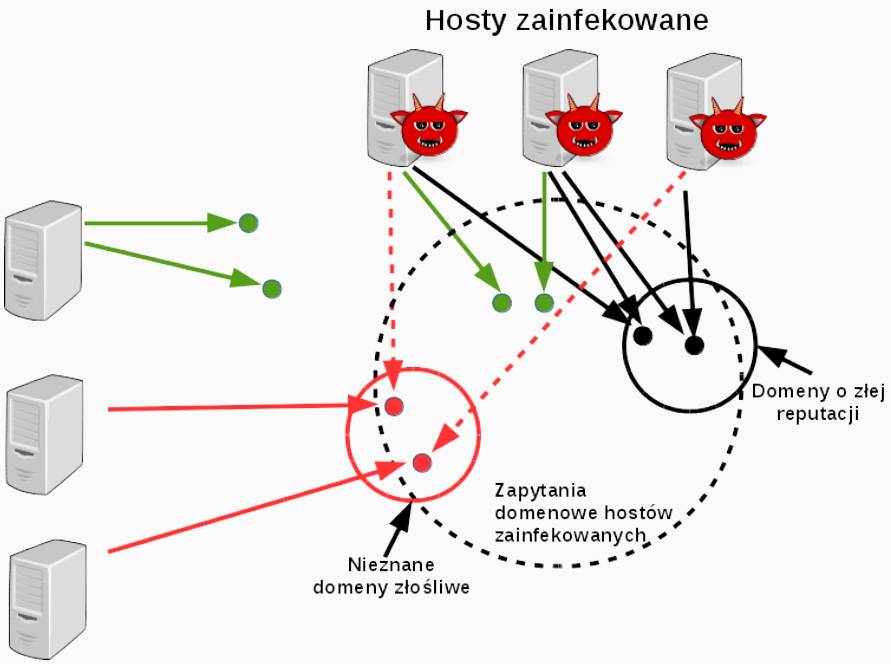
Extending Black Domain Name List by Using Co-occurrence Relation between DNS Queries, K. Sato i in.



1. Zebranie zapytań domenowych
2. Sprawdzenie, które stacje pytały o złośliwe domeny
3. Oznaczenie ich jako zainfekowane
4. Obliczenie miary współwystępowania dla innych domen - dodanie do blacklisty

KORELACJA ZACHOWAŃ

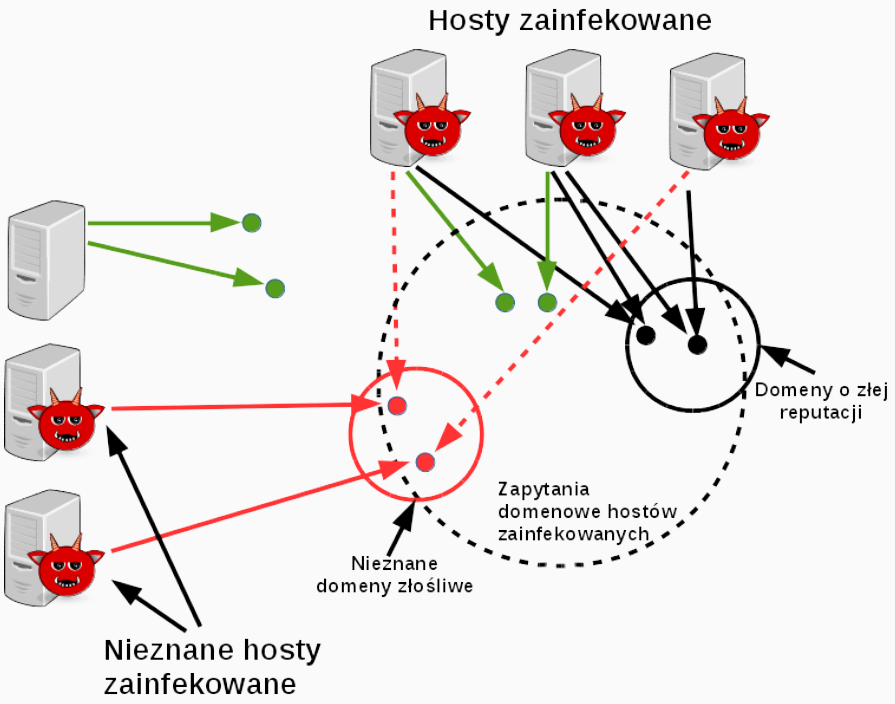
Extending Black Domain Name List by Using Co-occurrence Relation between DNS Queries, K. Sato i in.



1. Zebranie zapytań domenowych
2. Sprawdzenie, które stacje pytały o złośliwe domeny
3. Oznaczenie ich jako zainfekowane
4. Obliczenie miary współwystępowania dla innych domen - dodanie do blacklisty
5. Odnalezienie komputerów, które pytały o te nieznane wcześniej domeny

KORELACJA ZACHOWAŃ

Extending Black Domain Name List by Using Co-occurrence Relation between DNS Queries, K. Sato i in.

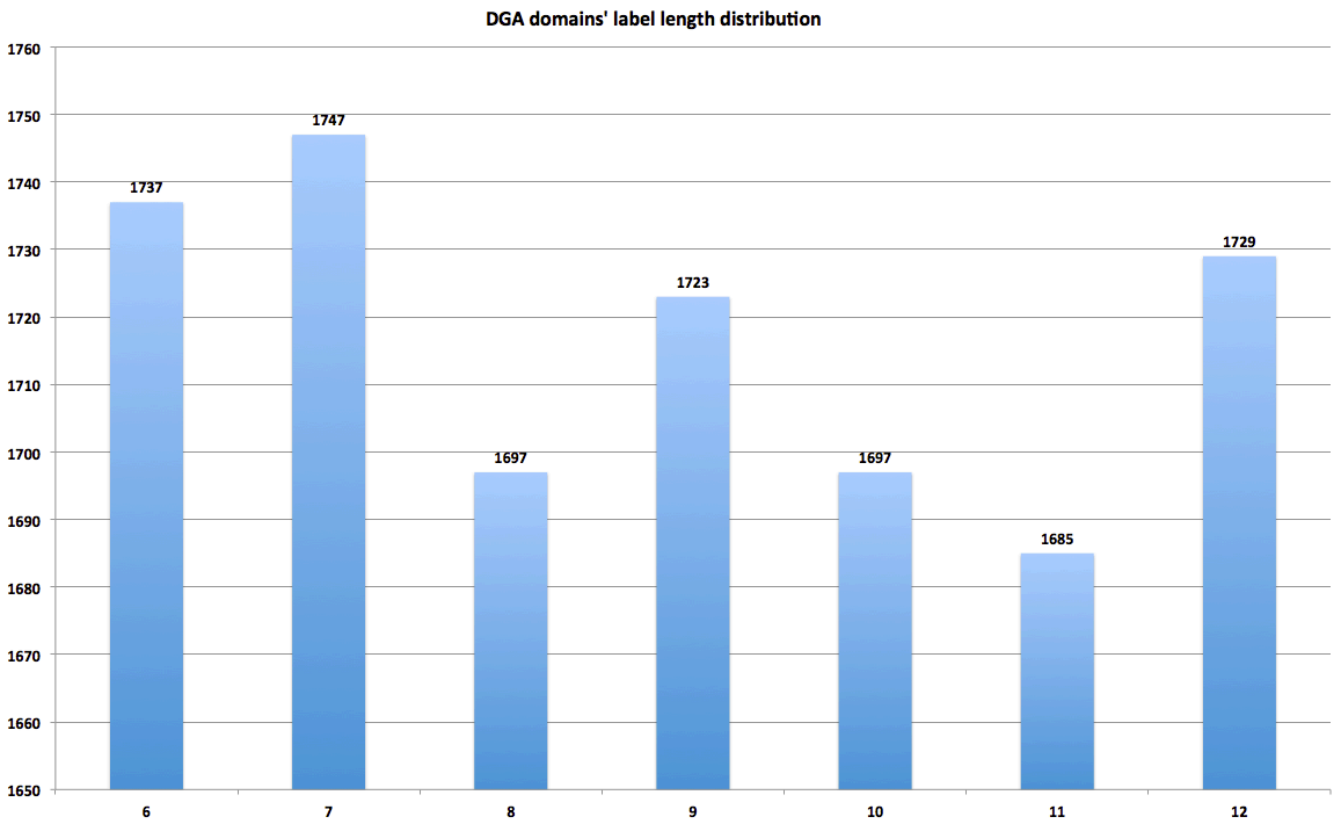


1. Zebranie zapytań domenowych
2. Sprawdzenie, które stacje pytały o złośliwe domeny
3. Oznaczenie ich jako zainfekowane
4. Obliczenie miary współwystępowania dla innych domen - dodanie do blacklisty
5. Odnalezienie komputerów, które pytały o te nieznane wcześniej domeny

CECHY DOMENY DGA

dvcdjghtwrs.com

CECHY LEKSYKALNE NAZW DOMENOWYCH



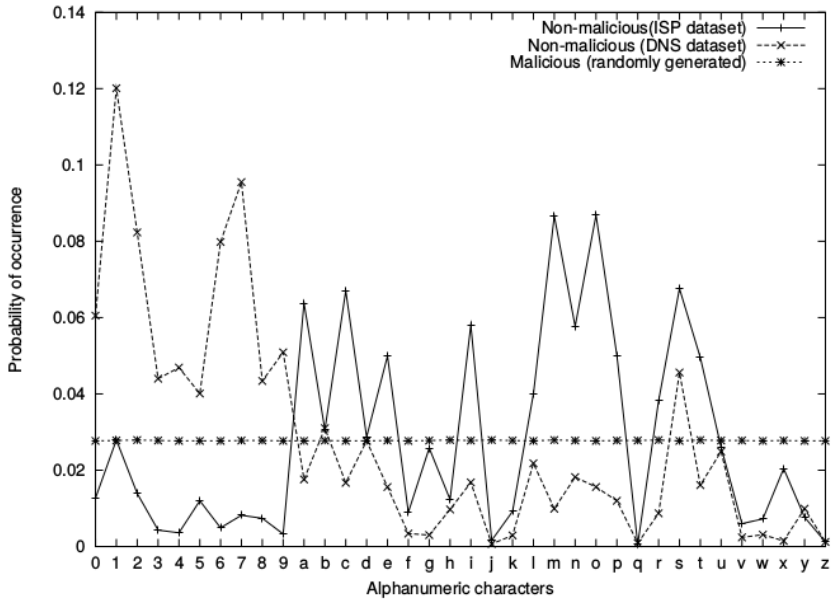
Rozkład długości nazw domenowych w zestawie 12000+ domen [2]

[2] OpenDNS Security Lab

WYKORZYSTANIE CECH LEKSYKALNYCH - PRZYKŁAD

Wykorzystywane cechy nazw domenowych:

- długość



(a) Non-malicious and malicious domains.

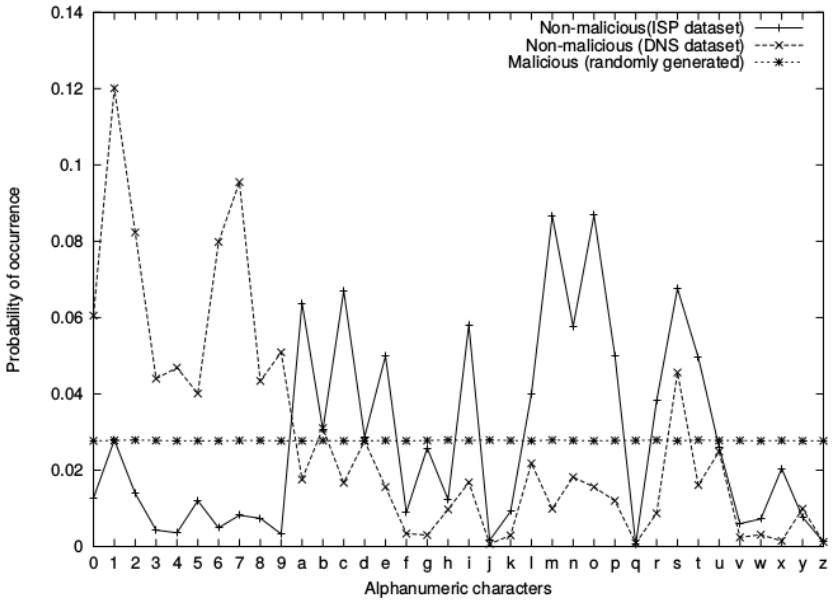
Figure 2: Źródło: S. Yadav i in. [3]

[3] Sandeep Yadav, Ashwath K.K. Reddy and A.L. Narasimha Reddy, *Detecting Algorithmically Generated Malicious Domain Names*

WYKORZYSTANIE CECH LEKSYKALNYCH - PRZYKŁAD

Wykorzystywane cechy nazw domenowych:

- długość
- entropia



(a) Non-malicious and malicious domains.

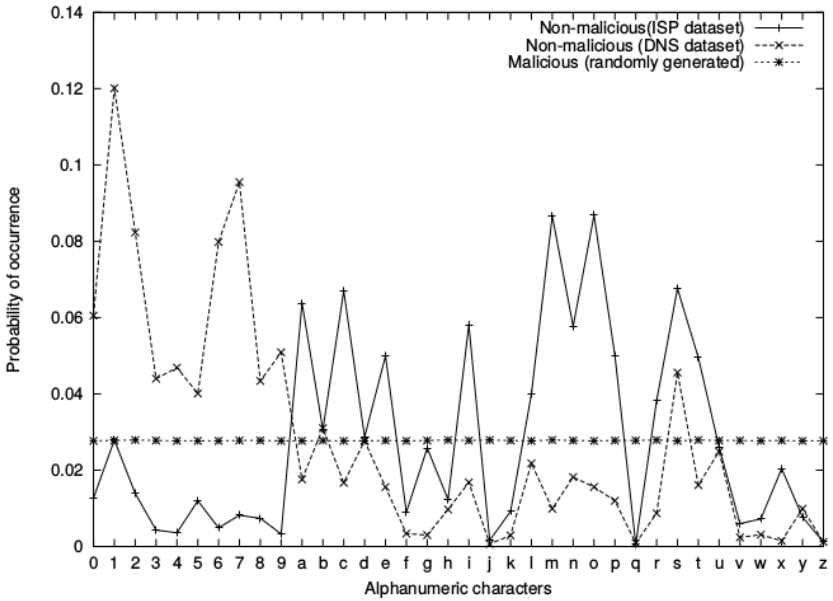
Figure 2: Źródło: S. Yadav i in. [3]

[3] Sandeep Yadav, Ashwath K.K. Reddy and A.L. Narasimha Reddy, *Detecting Algorithmically Generated Malicious Domain Names*

WYKORZYSTANIE CECH LEKSYKALNYCH - PRZYKŁAD

Wykorzystywane cechy nazw domenowych:

- długość
- entropia
- analiza n-gramów



(a) Non-malicious and malicious domains.

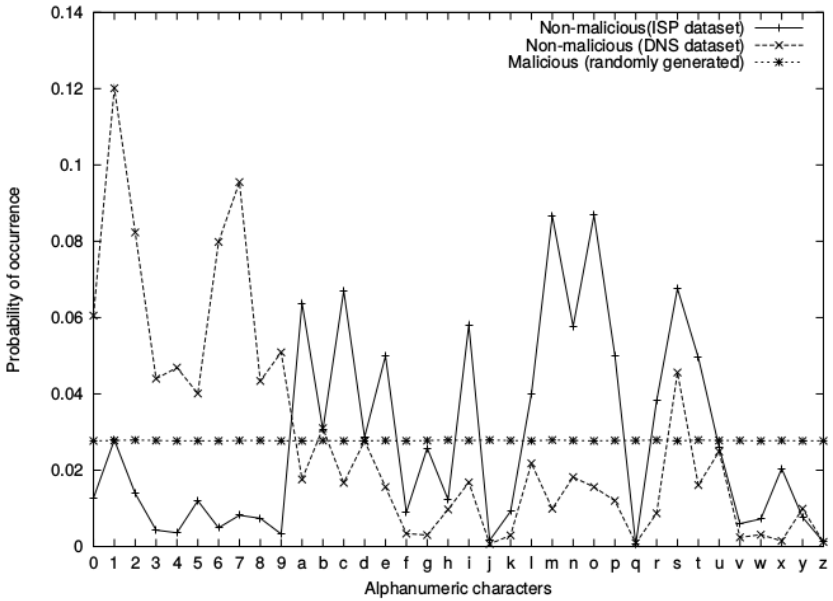
Figure 2: Źródło: S. Yadav i in. [3]

[3] Sandeep Yadav, Ashwath K.K. Reddy and A.L. Narasimha Reddy, *Detecting Algorithmically Generated Malicious Domain Names*

WYKORZYSTANIE CECH LEKSYKALNYCH - PRZYKŁAD

Wykorzystywane cechy nazw domenowych:

- długość
- entropia
- analiza n-gramów
- indeks Jaccarda pomiędzy bigramami



(a) Non-malicious and malicious domains.

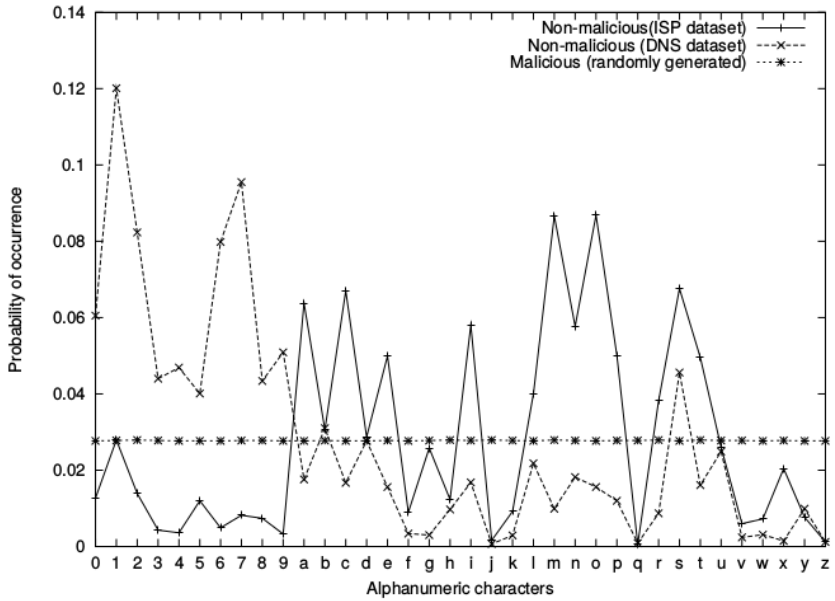
Figure 2: Źródło: S. Yadav i in. [3]

[3] Sandeep Yadav, Ashwath K.K. Reddy and A.L. Narasimha Reddy, *Detecting Algorithmically Generated Malicious Domain Names*

WYKORZYSTANIE CECH LEKSYKALNYCH - PRZYKŁAD

Wykorzystywane cechy nazw domenowych:

- długość
- entropia
- analiza n-gramów
- indeks Jaccarda pomiędzy bigramami
- odległość edycyjna



(a) Non-malicious and malicious domains.

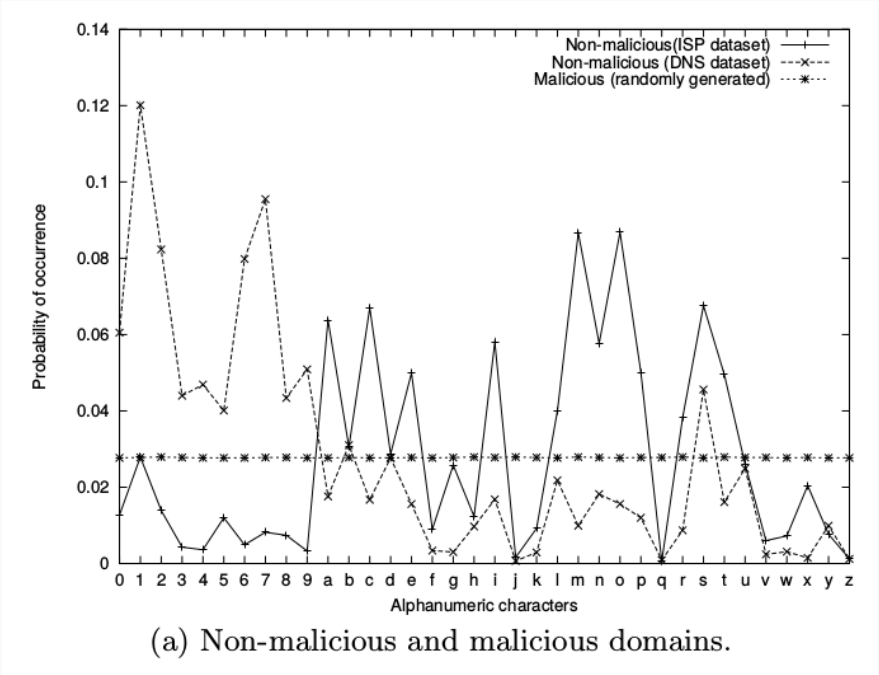
Figure 2: Źródło: S. Yadav i in. [3]

[3] Sandeep Yadav, Ashwath K.K. Reddy and A.L. Narasimha Reddy, *Detecting Algorithmically Generated Malicious Domain Names*

WYKORZYSTANIE CECH LEKSYKALNYCH - PRZYKŁAD

Wykorzystywane cechy nazw domenowych:

- długość
- entropia
- analiza n-gramów
- indeks Jaccarda pomiędzy bigramami
- odległość edycyjna
- ...



(a) Non-malicious and malicious domains.

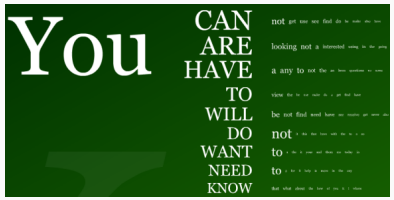
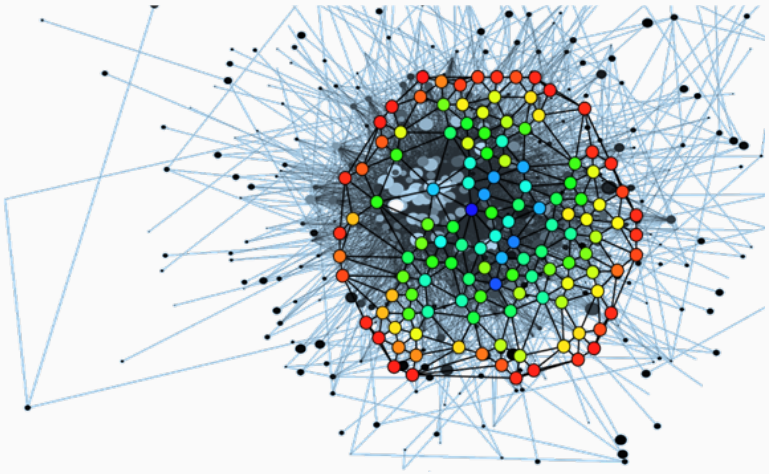


Figure 2: Źródło: S. Yadav i in. [3]

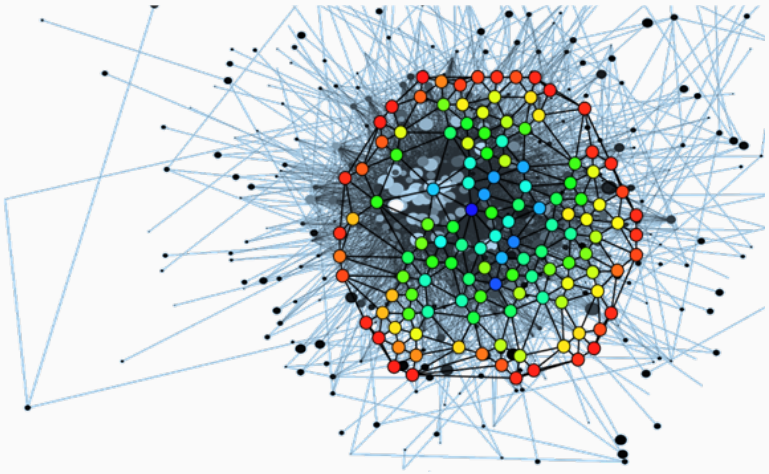
[3] Sandeep Yadav, Ashwath K.K. Reddy and A.L. Narasimha Reddy, *Detecting Algorithmically Generated Malicious Domain Names*

Cechy leksykalne lub bazujące na DNS mogą być wykorzystane przez algorytmy uczenia maszynowego do utworzenia modelu detekcji.



- potrzebna jest wiedza bazowa

Cechy leksykalne lub bazujące na DNS mogą być wykorzystane przez algorytmy uczenia maszynowego do utworzenia modelu detekcji.



- potrzebna jest wiedza bazowa
- używane są standardowe algorytmy: SVM, Random Forests, J48 itp.

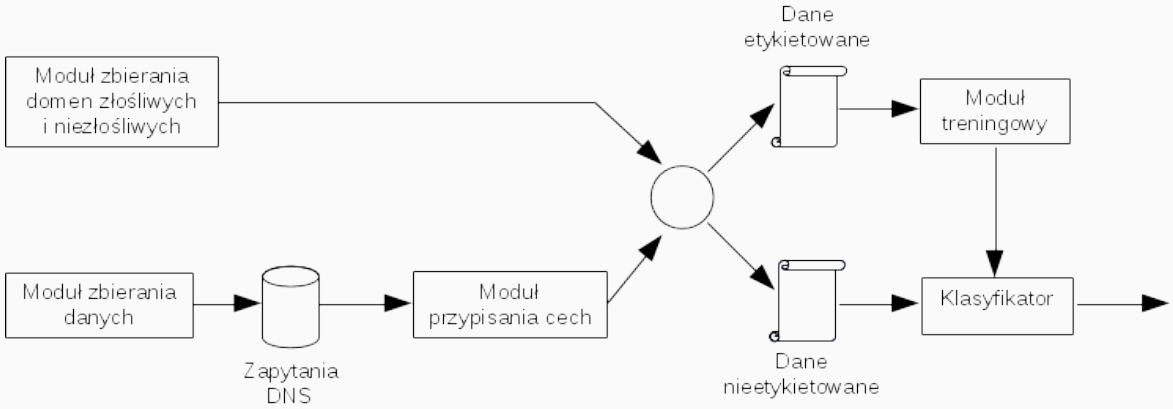
WYKORZYSTANIE RÓŻNYCH CECH DNS - EXPOSURE

System Exposure[4] wykorzystuje zarówno cechy leksykalne jak i własności DNS

[4] L. Bilge i in. *EXPOSURE: Finding Malicious Domains Using Passive DNS Analysis*

WYKORZYSTANIE RÓŻNYCH CECH DNS - EXPOSURE

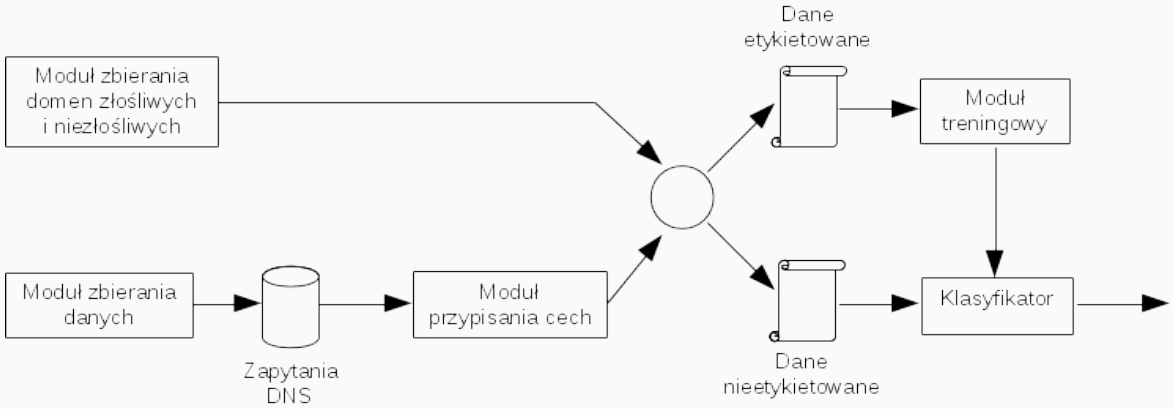
System Exposure[4] wykorzystuje zarówno cechy leksykalne jak i własności DNS



[4] L. Bilge i in. *EXPOSURE: Finding Malicious Domains Using Passive DNS Analysis*

WYKORZYSTANIE RÓŻNYCH CECH DNS - EXPOSURE

System Exposure[4] wykorzystuje zarówno cechy leksykalne jak i własności DNS



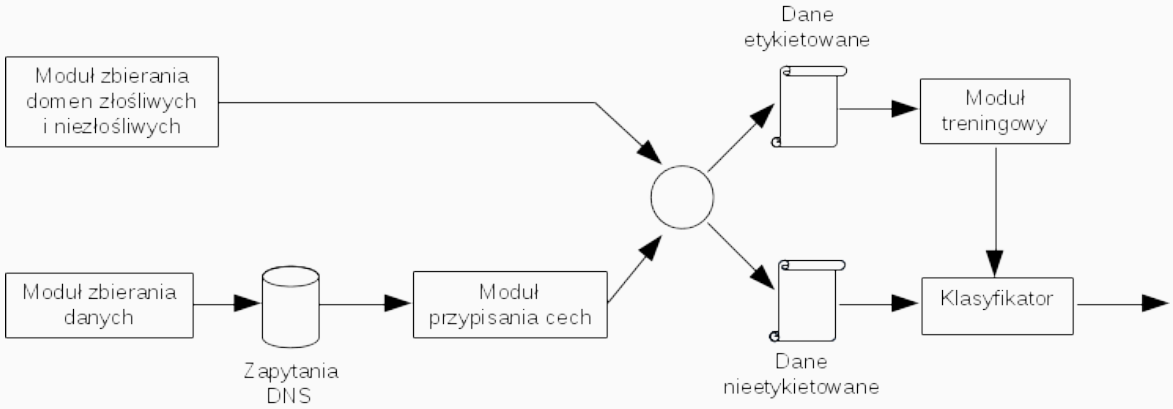
1. Obliczenie wartości cech dla danych treningowych

Zbiór	Nazwa cechy
cechy czasowe	1. krótki czas życia
	2. podobieństwo dzienne
	3. powtarzające się wzorce
	4. wskaźnik dostępu
cechy odpowiedzi DNS	5. liczba odrębnych adresów IP
	6. liczba odrębnych krajów
	7. liczba domen dzielących jeden adres IP
	8. rezultat odwrotnego zapytania DNS
cechy wartości TTL	9. średni TTL
	10. odchylenie standardowe TTL
	11. liczba odrębnych wartości TTL
	12. liczba zmian TTL
	13. procent użycia różnych zakresów TTL
cechy leksykalne nazwy domenowej	14. procent znaków numerycznych
	15. procent długości podsłów mających znaczenie w języku

[4] L. Bilge i in. *EXPOSURE: Finding Malicious Domains Using Passive DNS Analysis*

WYKORZYSTANIE RÓŻNYCH CECH DNS - EXPOSURE

System Exposure[4] wykorzystuje zarówno cechy leksykalne jak i własności DNS



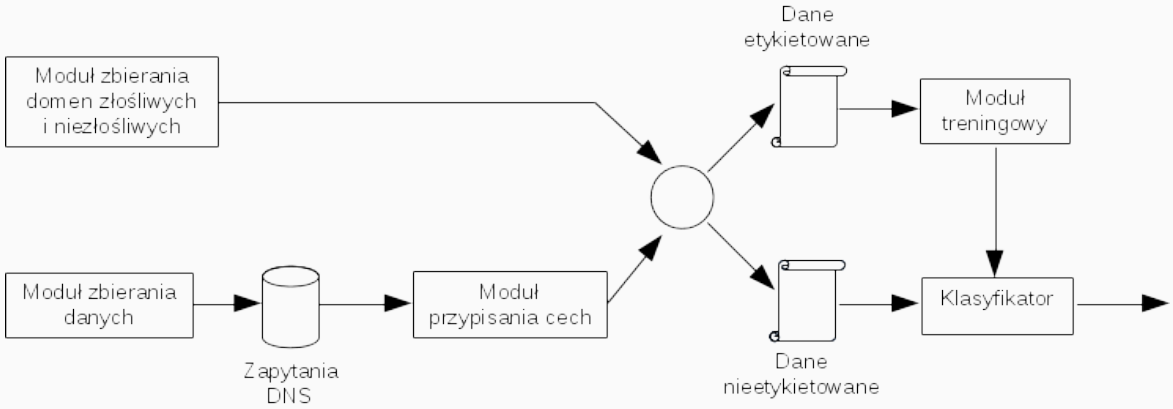
1. Obliczenie wartości cech dla danych treningowych
2. Stworzenie na tej bazie modelu (J48)

Zbiór	Nazwa cechy
cechy czasowe	1. krótki czas życia
	2. podobieństwo dzienne
	3. powtarzające się wzorce
	4. wskaźnik dostępu
cechy odpowiedzi DNS	5. liczba odrębnych adresów IP
	6. liczba odrębnych krajów
	7. liczba domen dzielących jeden adres IP
	8. rezultat odwrotnego zapytania DNS
cechy wartości TTL	9. średni TTL
	10. odchylenie standardowe TTL
	11. liczba odrębnych wartości TTL
	12. liczba zmian TTL
	13. procent użycia różnych zakresów TTL
cechy leksykalne nazwy domenowej	14. procent znaków numerycznych
	15. procent długości podsłów mających znaczenie w języku

[4] L. Bilge i in. *EXPOSURE: Finding Malicious Domains Using Passive DNS Analysis*

WYKORZYSTANIE RÓŻNYCH CECH DNS - EXPOSURE

System Exposure[4] wykorzystuje zarówno cechy leksykalne jak i własności DNS



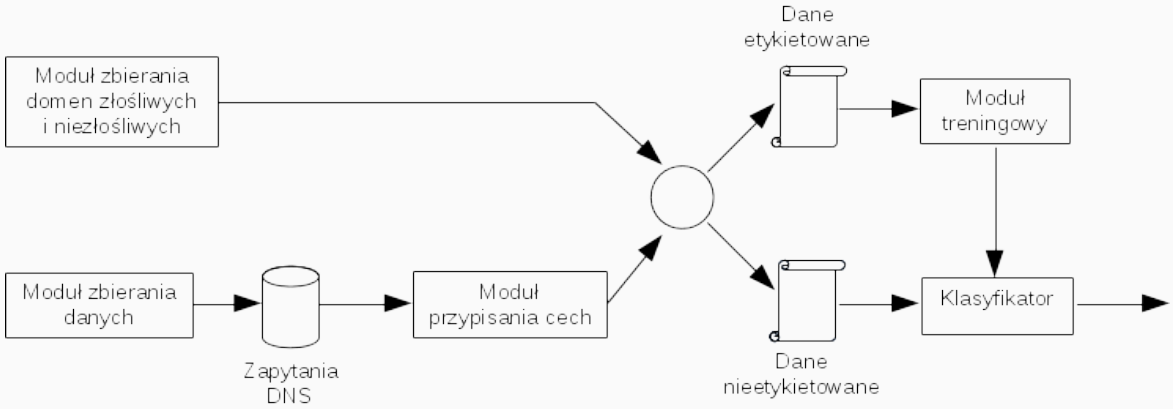
1. Obliczenie wartości cech dla danych treningowych
2. Stworzenie na tej bazie modelu (J48)
3. Obliczenie cech dla klientów

Zbiór	Nazwa cechy
cechy czasowe	1. krótki czas życia
	2. podobieństwo dzienne
	3. powtarzające się wzorce
	4. wskaźnik dostępu
cechy odpowiedzi DNS	5. liczba odrębnych adresów IP
	6. liczba odrębnych krajów
	7. liczba domen dzielących jeden adres IP
	8. rezultat odwrotnego zapytania DNS
cechy wartości TTL	9. średni TTL
	10. odchylenie standardowe TTL
	11. liczba odrębnych wartości TTL
	12. liczba zmian TTL
	13. procent użycia różnych zakresów TTL
cechy leksykalne nazwy domenowej	14. procent znaków numerycznych
	15. procent długości podsłów mających znaczenie w języku

[4] L. Bilge i in. *EXPOSURE: Finding Malicious Domains Using Passive DNS Analysis*

WYKORZYSTANIE RÓŻNYCH CECH DNS - EXPOSURE

System Exposure[4] wykorzystuje zarówno cechy leksykalne jak i własności DNS

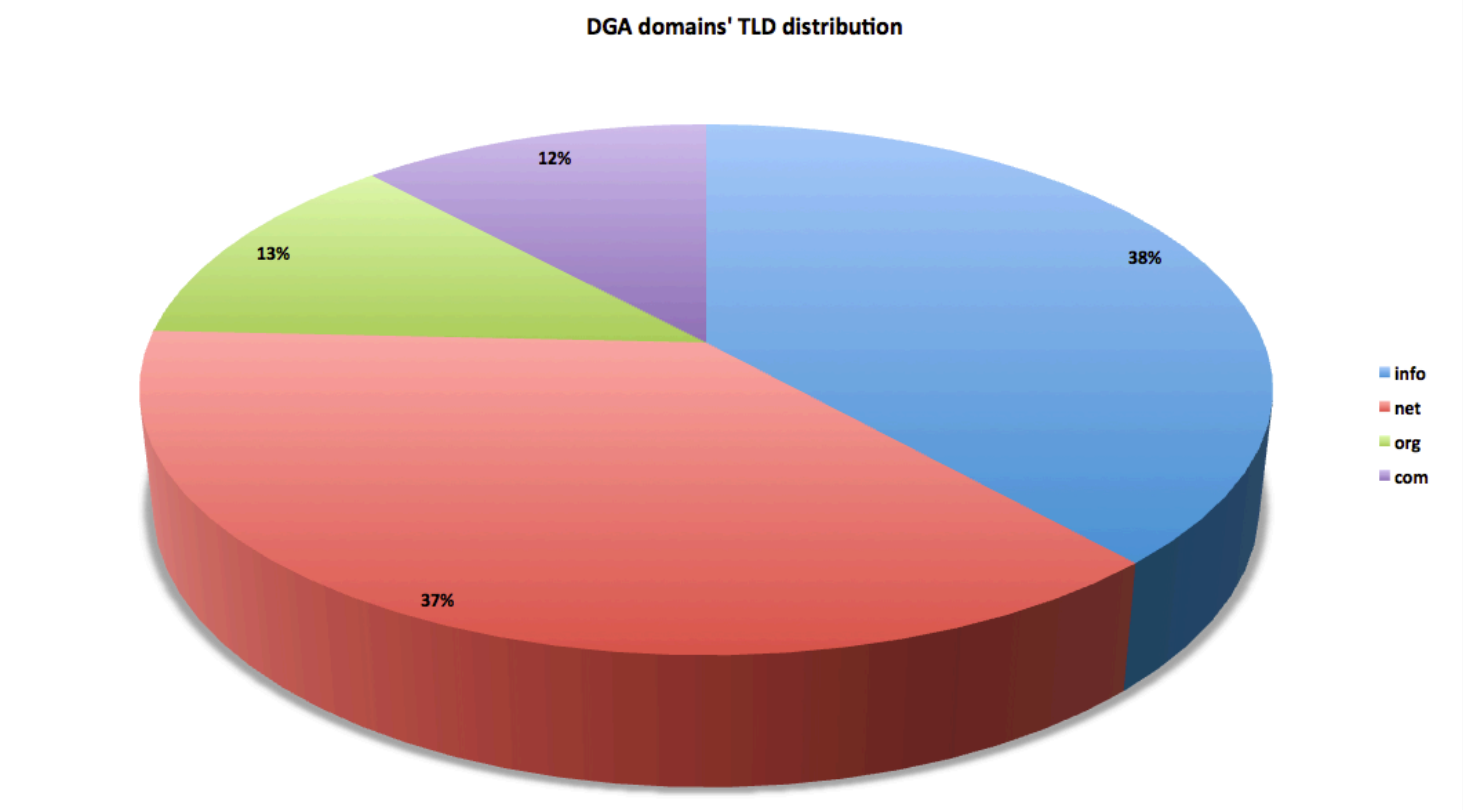


1. Obliczenie wartości cech dla danych treningowych
2. Stworzenie na tej bazie modelu (J48)
3. Obliczenie cech dla klientów
4. Klasyfikacja przez porównanie wyniku dla klienta z modelem

Zbiór	Nazwa cechy
cechy czasowe	1. krótki czas życia
	2. podobieństwo dzienne
	3. powtarzające się wzorce
	4. wskaźnik dostępu
cechy odpowiedzi DNS	5. liczba odrębnych adresów IP
	6. liczba odrębnych krajów
	7. liczba domen dzielących jeden adres IP
	8. rezultat odwrotnego zapytania DNS
cechy wartości TTL	9. średni TTL
	10. odchylenie standardowe TTL
	11. liczba odrębnych wartości TTL
	12. liczba zmian TTL
	13. procent użycia różnych zakresów TTL
cechy leksykalne nazwy domenowej	14. procent znaków numerycznych
	15. procent długości podsłów mających znaczenie w języku

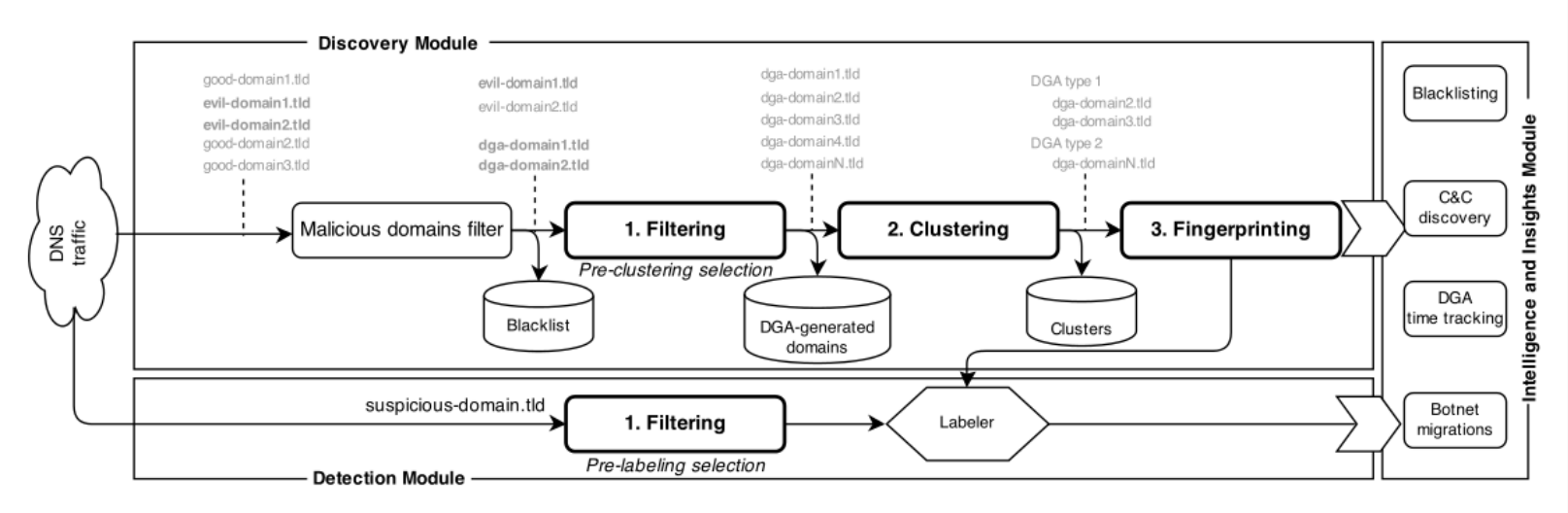
[4] L. Bilge i in. *EXPOSURE: Finding Malicious Domains Using Passive DNS Analysis*

UŻYCIE DOMEN NAJWYŻSZEGO POZIOMU PRZEZ DGA



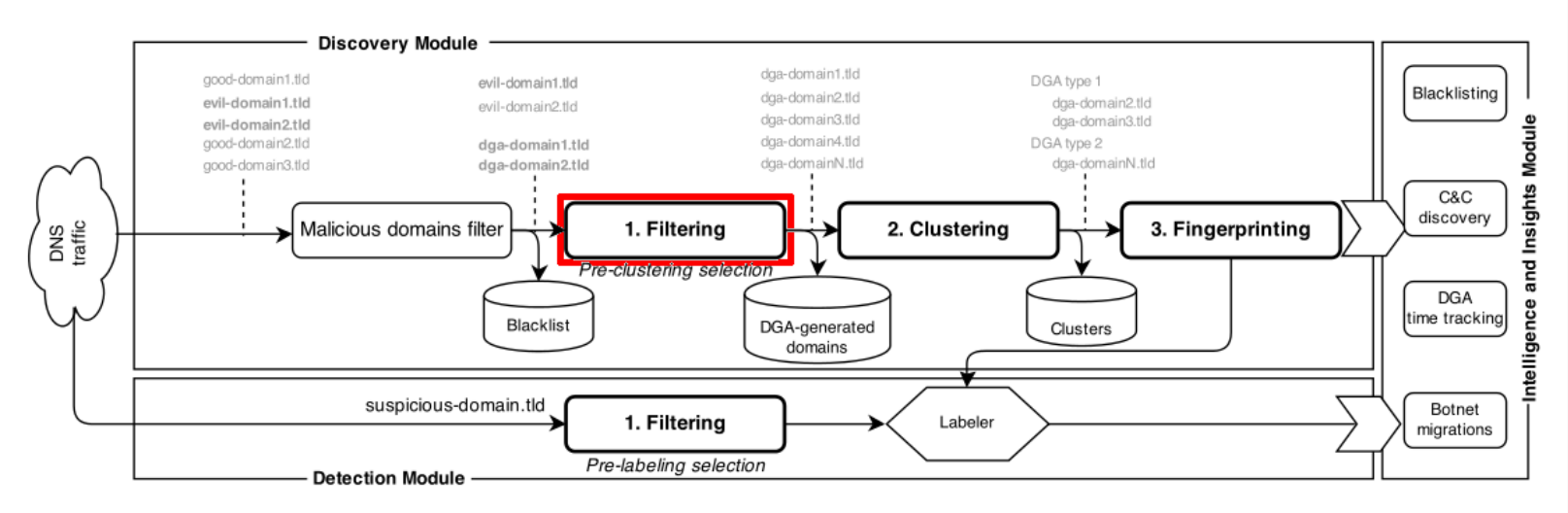
Źródło: OpenDNS Security Lab

METODY HYBRYDOWE - PHOENIX



[4] Stefano Schiavoni, Federico Maggi, Lorenzo Cavallaro, Stefano Zanero, *Phoenix: DGA-Based Botnet Tracking and Intelligence*

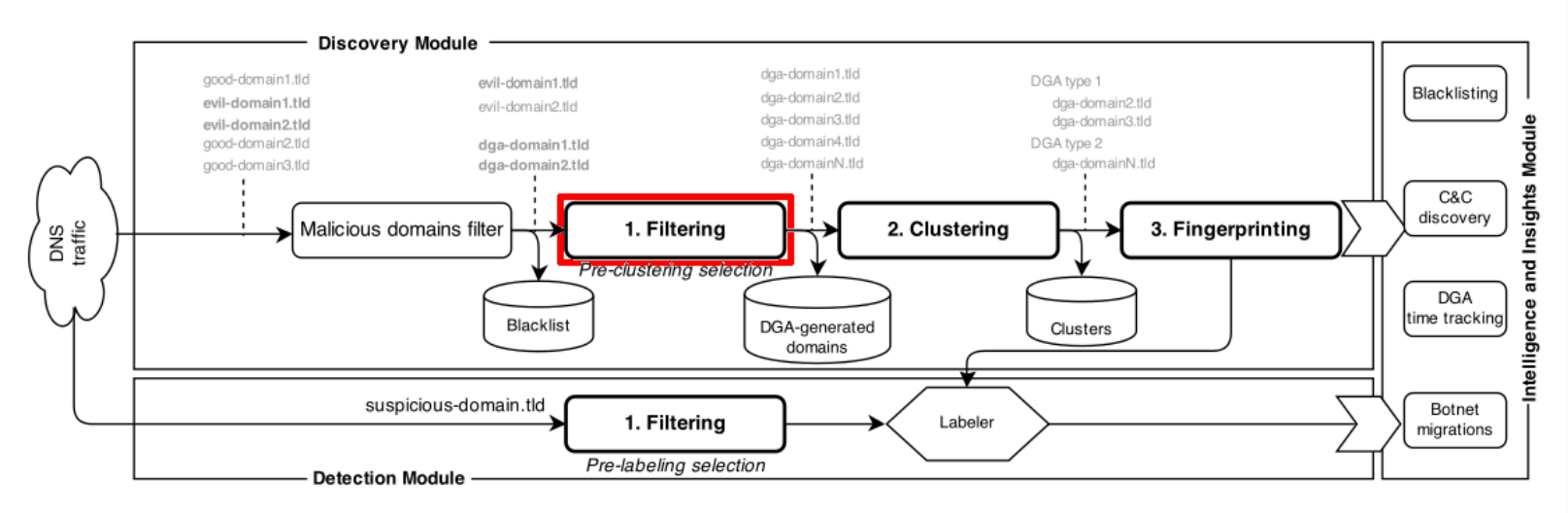
METODY HYBRYDOWE - PHOENIX



- Filtrowanie poprawnych odpowiedzi

[4] Stefano Schiavoni, Federico Maggi, Lorenzo Cavallaro, Stefano Zanero, *Phoenix: DGA-Based Botnet Tracking and Intelligence*

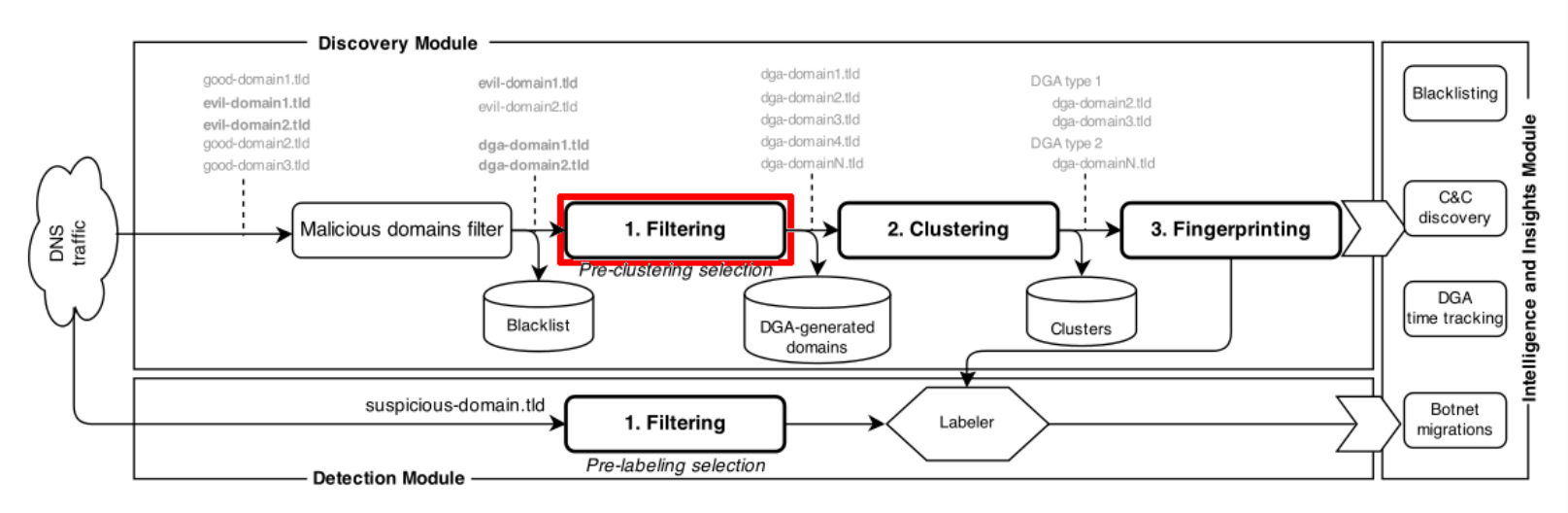
METODY HYBRYDOWE - PHOENIX



- Filtrowanie poprawnych odpowiedzi
  1. analiza leksykalna domen Alexy top 100k

[4] Stefano Schiavoni, Federico Maggi, Lorenzo Cavallaro, Stefano Zanero, *Phoenix: DGA-Based Botnet Tracking and Intelligence*

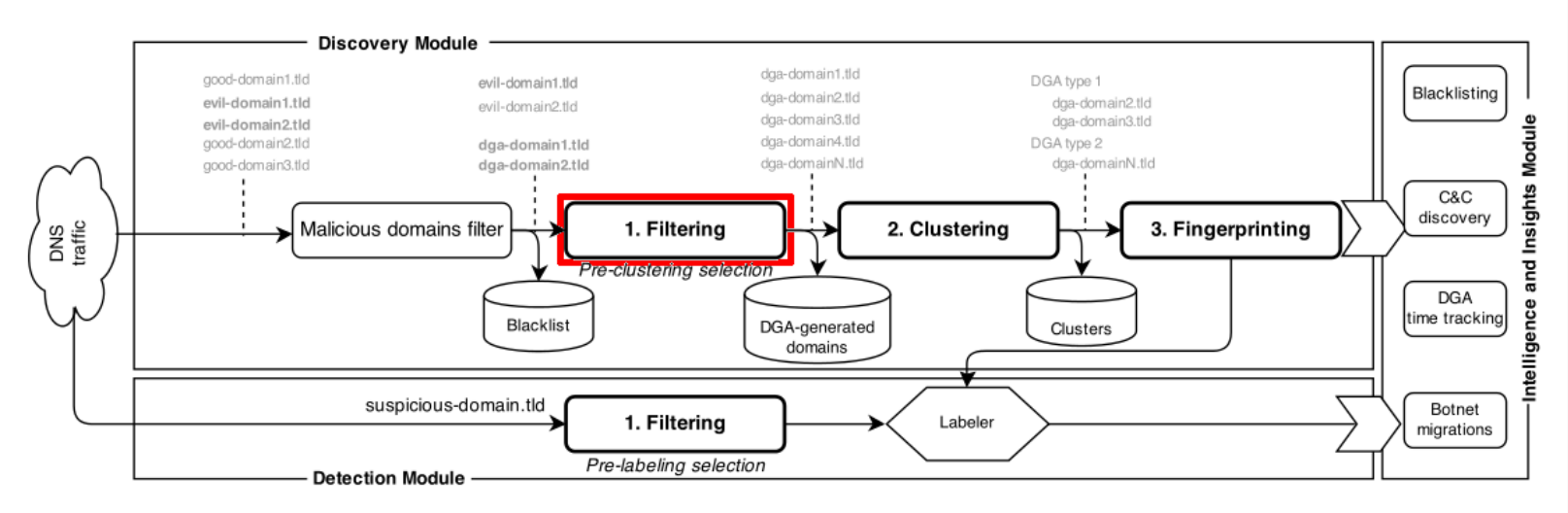
METODY HYBRYDOWE - PHOENIX



- Filtrowanie poprawnych odpowiedzi
  1. analiza leksykalna domen Alexy top 100k
  2. wypowiadalność, długość podsłów

[4] Stefano Schiavoni, Federico Maggi, Lorenzo Cavallaro, Stefano Zanero, *Phoenix: DGA-Based Botnet Tracking and Intelligence*

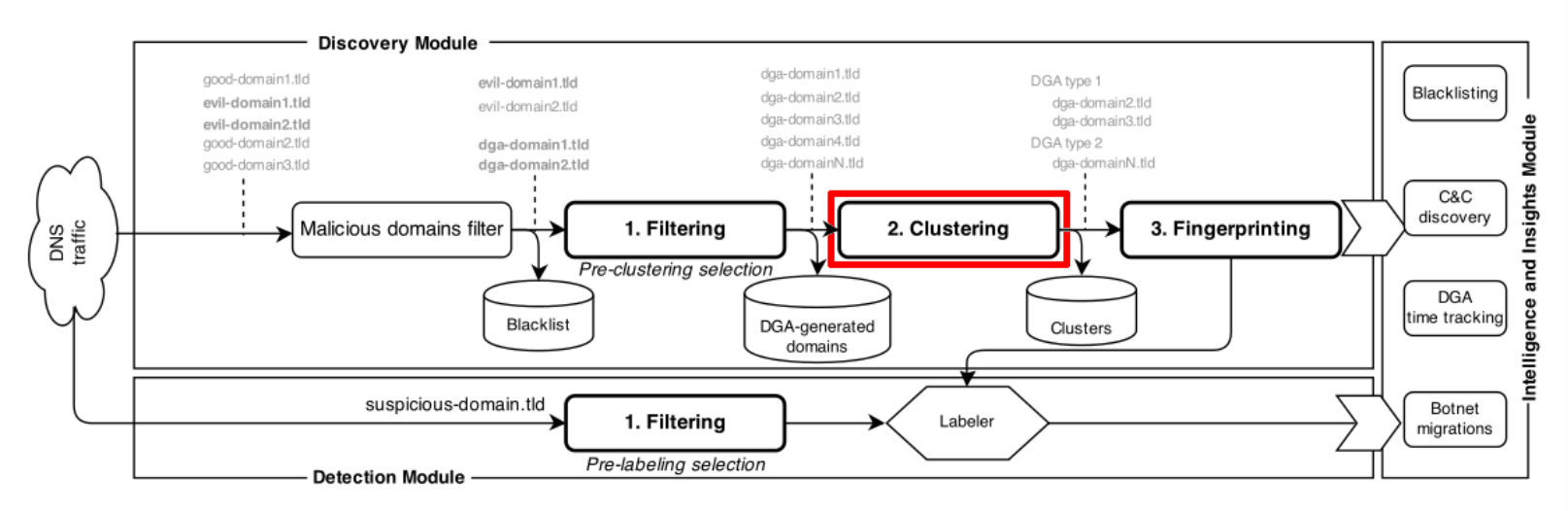
METODY HYBRYDOWE - PHOENIX



- Filtrowanie poprawnych odpowiedzi
  1. analiza leksykalna domen Alexy top 100k
  2. wypowiadalność, długość podsłów
  3. domeny odstające oznaczane jako DGA

[4] Stefano Schiavoni, Federico Maggi, Lorenzo Cavallaro, Stefano Zanero, *Phoenix: DGA-Based Botnet Tracking and Intelligence*

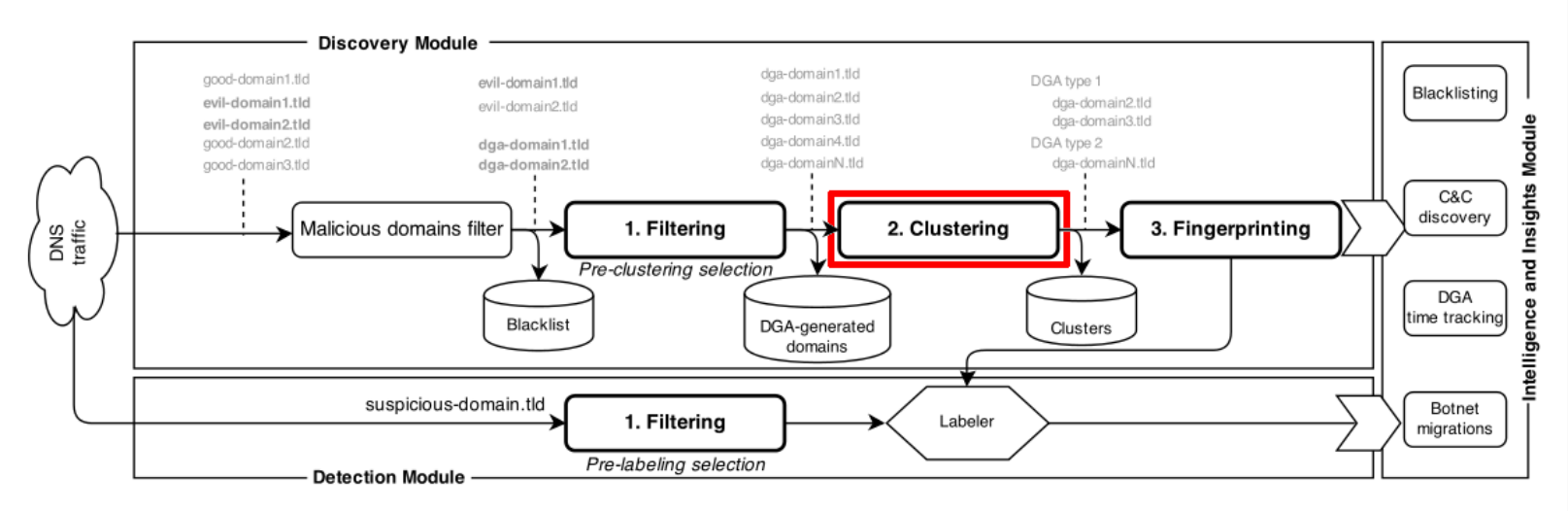
Phoenix: DGA-Based Botnet Tracking and Intelligence[5]



- Klastrowanie z użyciem grafów dwudzielnych

[5] Stefano Schiavoni, Federico Maggi, Lorenzo Cavallaro, Stefano Zanero, *Phoenix: DGA-Based Botnet Tracking and Intelligence*

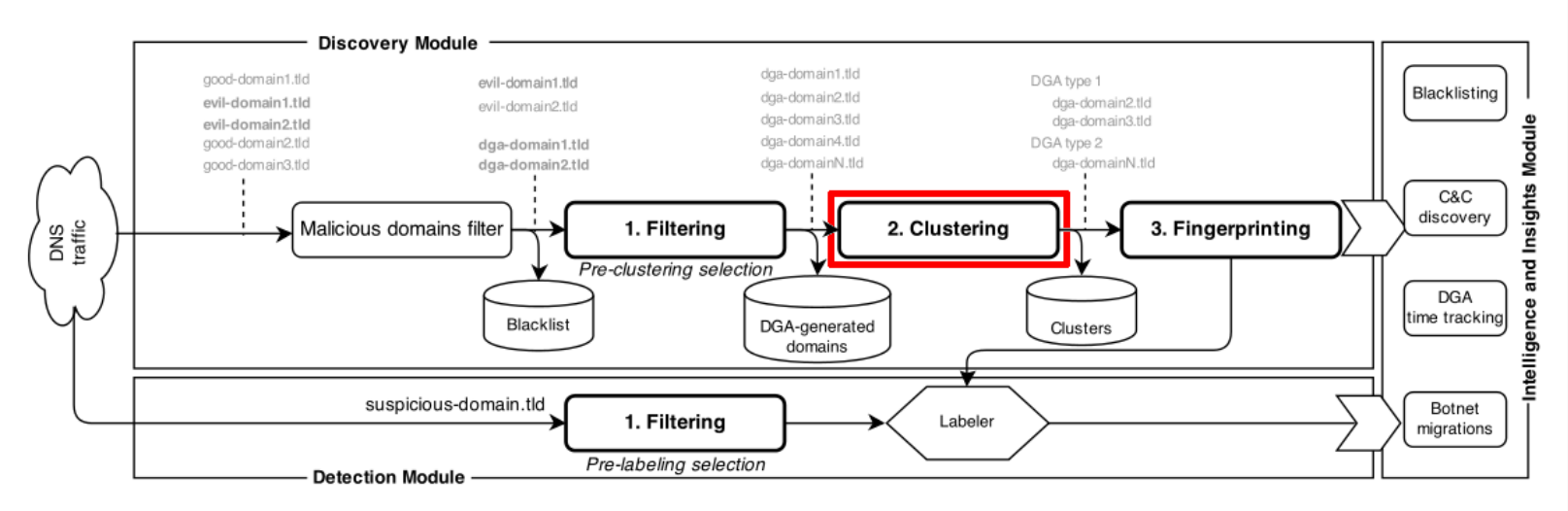
Phoenix: DGA-Based Botnet Tracking and Intelligence[5]



- Klastrowanie z użyciem grafów dwudzielnych
  1. cechy adresu IP

[5] Stefano Schiavoni, Federico Maggi, Lorenzo Cavallaro, Stefano Zanero, *Phoenix: DGA-Based Botnet Tracking and Intelligence*

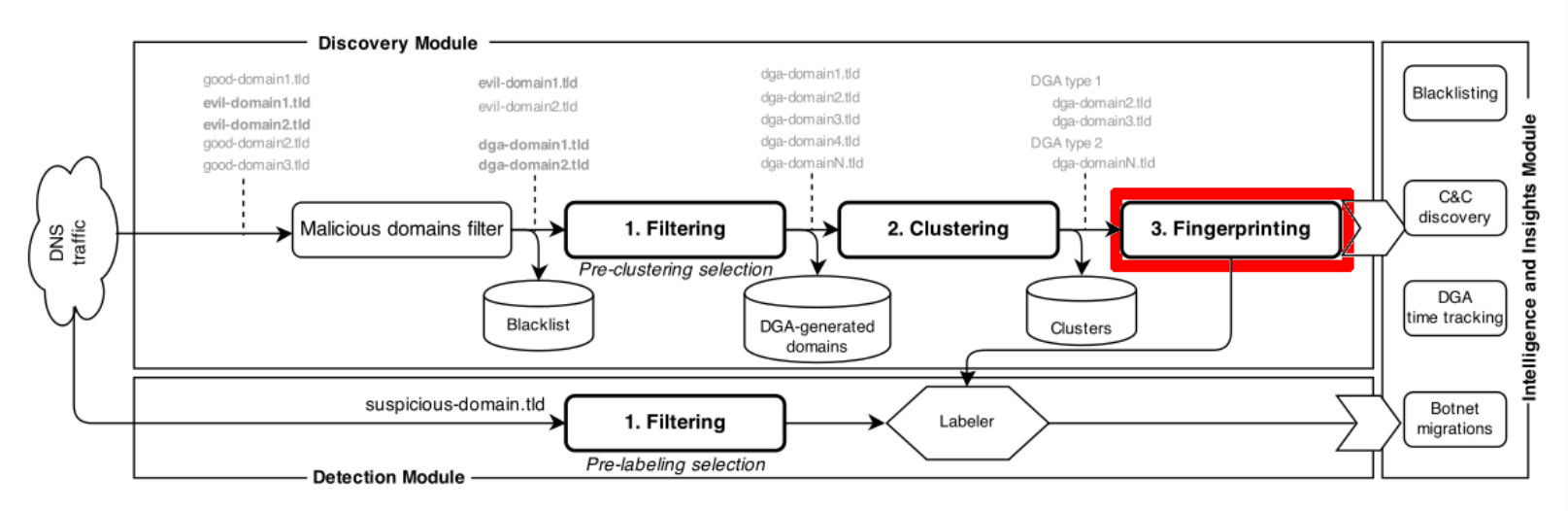
Phoenix: DGA-Based Botnet Tracking and Intelligence[5]



- Klastrowanie z użyciem grafów dwudzielnych
  1. cechy adresu IP
  2. algorytm DBSCAN

[5] Stefano Schiavoni, Federico Maggi, Lorenzo Cavallaro, Stefano Zanero, *Phoenix: DGA-Based Botnet Tracking and Intelligence*

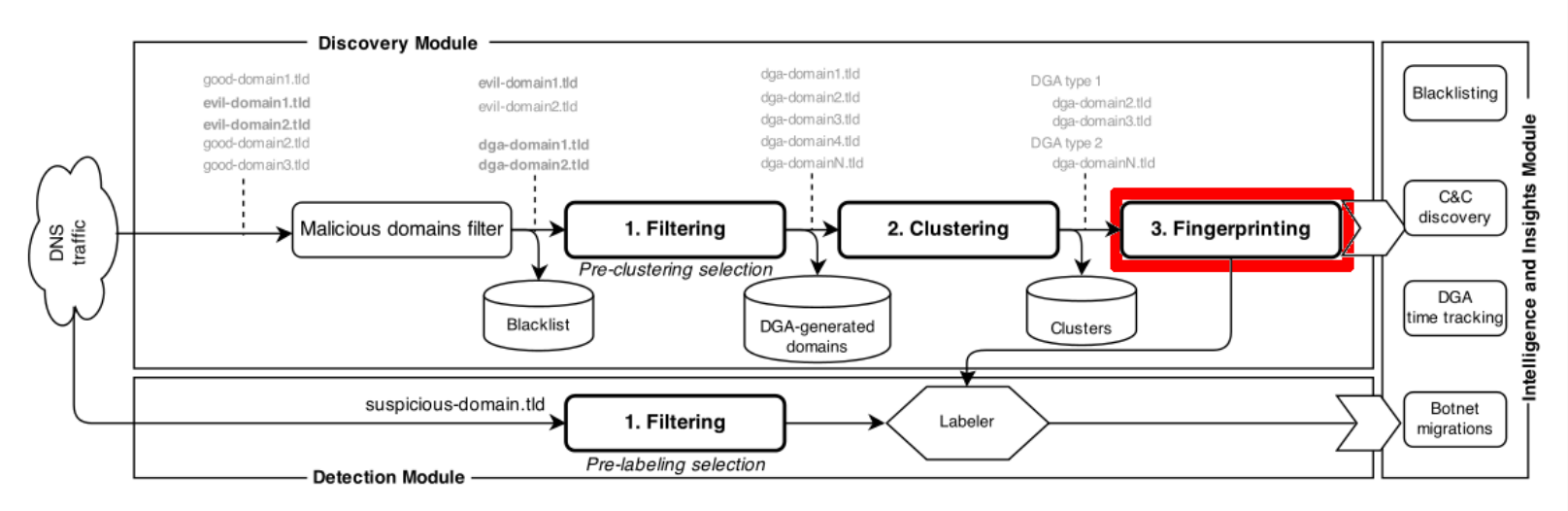
Phoenix: DGA-Based Botnet Tracking and Intelligence[5]



- Klastrowanie z użyciem grafów dwudzielnych
  1. cechy adresu IP
  2. algorytm DBSCAN
- Fingerprinting

[5] Stefano Schiavoni, Federico Maggi, Lorenzo Cavallaro, Stefano Zanero, *Phoenix: DGA-Based Botnet Tracking and Intelligence*

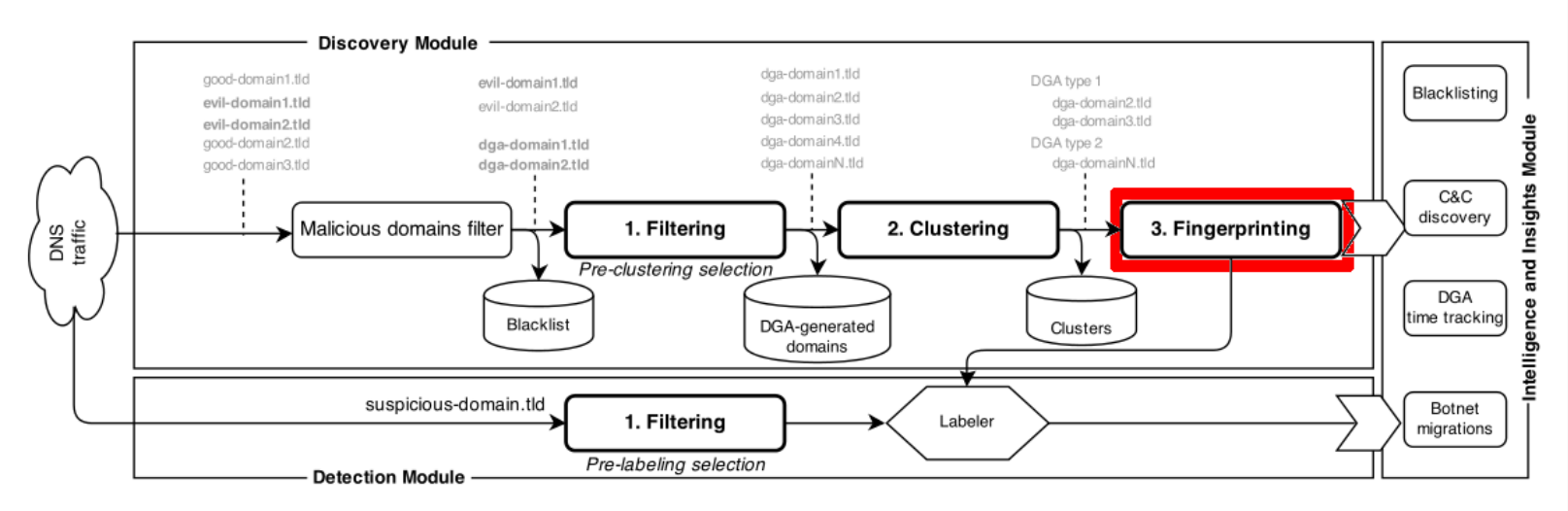
Phoenix: DGA-Based Botnet Tracking and Intelligence[5]



- Klastrowanie z użyciem grafów dwudzielnych
  1. cechy adresu IP
  2. algorytm DBSCAN
- Fingerprinting
  1. adresy IP serwerów C&C

[5] Stefano Schiavoni, Federico Maggi, Lorenzo Cavallaro, Stefano Zanero, *Phoenix: DGA-Based Botnet Tracking and Intelligence*

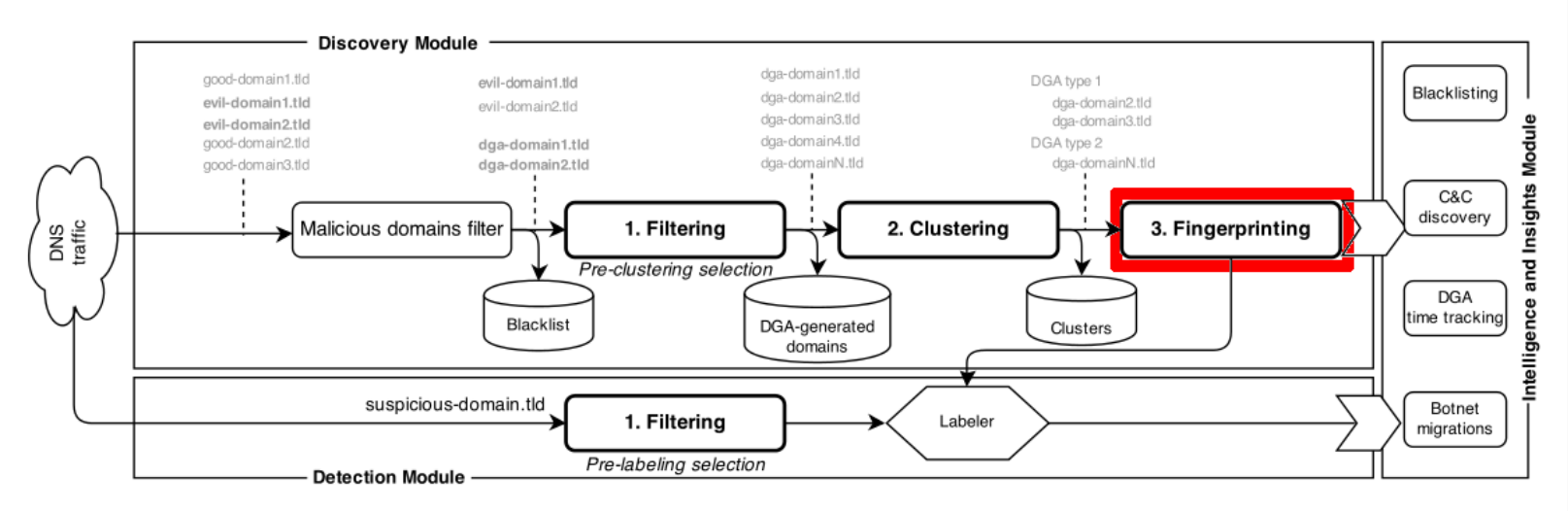
Phoenix: DGA-Based Botnet Tracking and Intelligence[5]



- Klastrowanie z użyciem grafów dwudzielnych
  1. cechy adresu IP
  2. algorytm DBSCAN
- Fingerprinting
  1. adresy IP serwerów C&C
  2. dalsze cechy leksykalne (zestaw znaków, długość, ...)

[5] Stefano Schiavoni, Federico Maggi, Lorenzo Cavallaro, Stefano Zanero, *Phoenix: DGA-Based Botnet Tracking and Intelligence*

Phoenix: DGA-Based Botnet Tracking and Intelligence[5]



- Klastrowanie z użyciem grafów dwudzielnych
  1. cechy adresu IP
  2. algorytm DBSCAN
- Fingerprinting
  1. adresy IP serwerów C&C
  2. dalsze cechy leksykalne (zestaw znaków, długość, ...)
  3. zestaw domen najwyższego poziomu

[5] Stefano Schiavoni, Federico Maggi, Lorenzo Cavallaro, Stefano Zanero, *Phoenix: DGA-Based Botnet Tracking and Intelligence*

STATYSTYKI WYKRYCIA

Metoda	TPR [%]	FPR [%]
Korelacja - GMAD[6]	84 [precyzja]	0.3
Leksykalne - Stalmans[7]	82	8.3
Różne cechy DNS - Exposure	98.4	1.1
Hybrydowa - Phoenix	94.8	b.d.

Zastrzeżenie:
Zostały podane przez autorów prac. Dodatkowo badania dokonane zostały dla różnych zbiorów danych testowych.

[6] J. Lee, H. Lee, *GMAD: Graph-based Malware Activity Detection by DNS traffic analysis*
[7] E. Stalmans, *A Framework for DNS based detection and mitigation of malware infections on a network*

PODSUMOWANIE

PODSUMOWANIE

- Algorytmy DGA wprowadzono dla utrudnienia wykrycia botnetów

PODSUMOWANIE

- Algorytmy DGA wprowadzono dla utrudnienia wykrycia botnetów
- Sygnatury są w tym wypadku niewydajne

PODSUMOWANIE

- Algorytmy DGA wprowadzono dla utrudnienia wykrycia botnetów
- Sygnatury są w tym wypadku niewydajne
  - Statyczność sygnatur, brak heurystyki

PODSUMOWANIE

- Algorytmy DGA wprowadzono dla utrudnienia wykrycia botnetów
- Sygnatury są w tym wypadku niewydajne
  - Statyczność sygnatur, brak heurystyki
  - Niezłośliwe domeny DGA

PODSUMOWANIE

- Algorytmy DGA wprowadzono dla utrudnienia wykrycia botnetów
- Sygnatury są w tym wypadku niewydajne
  - Statyczność sygnatur, brak heurystyki
  - Niezłośliwe domeny DGA
- Konieczność użycia zaawansowanych metod wykrycia

PODSUMOWANIE

- Algorytmy DGA wprowadzono dla utrudnienia wykrycia botnetów
- Sygnatury są w tym wypadku niewydajne
  - Statyczność sygnatur, brak heurystyki
  - Niezłośliwe domeny DGA
- Konieczność użycia zaawansowanych metod wykrycia
- Rozwiązaniem są systemy dedykowane

Pytania?